Expediente técnico integral para proyecto de tesis

Desarrollo de una aplicación web para la gestión documental institucional digitalizada basada en estándares de seguridad con énfasis en ISO/IEC 27001:2022, ISO 15489 y OWASP ASVS, en el GADPR-LM

Institución beneficiaria: GADPR-LM
Versión: 1.0
Fecha: 19 de abril de 2026
Equipo técnico: Autor o equipo técnico del proyecto de tesis, con apoyo de análisis, arquitectura, desarrollo y seguridad (genérico)
Entorno de aplicación: Intranet institucional
Tipo de sistema: Aplicación web institucional para gestión documental digitalizada

---

Supuestos propuestos

1. **Supuesto propuesto sobre la sigla institucional:** se asume que "GADPR-LM" corresponde a la sigla oficial de la institución beneficiaria proporcionada por el solicitante. El nombre expandido deberá confirmarse en la fase de levantamiento final.
2. **Supuesto propuesto sobre infraestructura:** se asume la existencia de una red local institucional con uno o más servidores internos, respaldo eléctrico básico y personal TIC con acceso administrativo.
3. **Supuesto propuesto sobre digitalización:** se asume que los documentos podrán provenir tanto de carga manual de archivos existentes como de escaneo mediante equipos institucionales.
4. **Supuesto propuesto sobre correo interno:** se asume la disponibilidad de un servicio de correo institucional o pasarela interna para notificaciones y recuperación de credenciales.
5. **Supuesto propuesto sobre volumen documental:** se asume un crecimiento gradual y sostenido del repositorio, por lo que el diseño debe privilegiar trazabilidad, integridad, mantenibilidad y escalabilidad básica.

> **Nota de ajuste académico:** el presente documento se encuentra redactado y estructurado como **expediente técnico base para un proyecto de tesis**, por lo que combina enfoque profesional de ingeniería de software con utilidad académica para sustentar el análisis, diseño, desarrollo, pruebas, implementación y defensa técnica de la investigación aplicada.

Enfoque del documento dentro del proyecto de tesis

Este expediente no debe entenderse únicamente como una guía operativa para construir el sistema, sino también como un **instrumento técnico-académico de tesis**. En consecuencia,

su redacción se alinea con los fines de una investigación aplicada orientada a resolver un problema real del GADPR-LM mediante una solución informática.
Por ello, el documento cumple simultáneamente cuatro funciones:

1. **Función académica:** sirve como sustento técnico del proyecto de titulación, permitiendo demostrar que la propuesta no es solo conceptual, sino viable, estructurada y desarrollable.
2. **Función metodológica:** organiza el paso a paso del sistema para que pueda ser incorporado o citado dentro de capítulos de tesis como análisis, diseño, propuesta tecnológica, validación y resultados esperados.
3. **Función profesional:** orienta a analistas, desarrolladores, administradores y responsables institucionales sobre cómo debe construirse e implantarse la solución.
4. **Función documental:** deja evidencia formal de criterios de arquitectura, base de datos, seguridad, trazabilidad, controles y alcance, útiles tanto para la tesis como para una futura ejecución real.

En este sentido, cuando el documento se refiere al sistema, a la arquitectura, a la base de datos, a las pruebas y a la implementación, debe interpretarse que dichos elementos conforman la **propuesta tecnológica central del proyecto de tesis**.

Tabla de contenido

1. Portada técnica del proyecto
2. Resumen ejecutivo
3. Antecedentes y problemática
4. Justificación técnica
5. Objetivo general y objetivos específicos
6. Alcance del sistema
7. Marco normativo y técnico aplicable
8. Metodología de desarrollo recomendada
9. Levantamiento y análisis de requerimientos
10. Identificación de actores del sistema
11. Arquitectura general del sistema
12. Diseño completo del sistema por módulos
13. Diseño detallado de navegación
14. Flujo de procesos del sistema
15. Reglas de negocio
16. Diseño de la base de datos
17. Diseño de formularios y campos
18. Reportes del sistema
19. Seguridad del sistema
20. Diseño de experiencia de usuario e interfaz
21. Diseño de pruebas
22. Plan de implementación
23. Plan de mantenimiento

24. Riesgos del proyecto y mitigación
25. Conclusiones y recomendaciones técnicas

---

1. Portada técnica del proyecto

Nombre del proyecto: Desarrollo de una aplicación web para la gestión documental institucional digitalizada basada en estándares de seguridad con énfasis en ISO/IEC 27001:2022, ISO 15489 y OWASP ASVS, en el GADPR-LM

Institución beneficiaria: GADPR-LM
Área de desarrollo: Transformación digital, gestión documental, seguridad de la información y gobierno de datos
Tema técnico: Diseño, construcción e implementación de un sistema web de gestión documental digitalizada con controles de seguridad, trazabilidad y conservación documental
Versión del expediente: 1.0
Fecha del expediente: 19 de abril de 2026
Autor o equipo técnico: Equipo técnico multidisciplinario de arquitectura de software, análisis funcional, base de datos, seguridad y aseguramiento de calidad
Entorno de aplicación: Red local institucional (intranet), con posibilidad de extensión futura a acceso controlado por VPN
Tipo de sistema: Sistema web institucional transaccional y de consulta, orientado a repositorio documental, clasificación archivística, trazabilidad y reportes

---

2. Resumen ejecutivo

El presente expediente técnico desarrolla de forma integral la propuesta para construir una aplicación web institucional destinada a la gestión documental digitalizada del GADPR-LM. El sistema responde a la necesidad de organizar, registrar, clasificar, almacenar, consultar, proteger y auditar documentos institucionales en formato digital, reduciendo la dispersión informativa, mejorando los tiempos de respuesta administrativa y fortaleciendo el control sobre el ciclo de vida de los documentos.

La solución propuesta aborda un problema recurrente en instituciones públicas: la coexistencia de documentos físicos y digitales sin estructura uniforme, con registros dispersos, búsquedas lentas, duplicidad de información, riesgo de pérdida, accesos no autorizados y escasa trazabilidad sobre quién consultó, modificó o descargó cada documento. En este contexto, el sistema permitirá centralizar metadatos, controlar versiones, establecer estados documentales, administrar permisos por rol y dependencia, generar reportes de gestión y mantener evidencia de auditoría sobre todas las acciones relevantes.

Desde la perspectiva de seguridad de la información, el proyecto se fundamenta en tres ejes: **confidencialidad**, **integridad** y **disponibilidad**. Para ello, adopta controles inspirados en **ISO/IEC 27001:2022**, principios archivísticos basados en **ISO 15489** y requisitos de seguridad

web inspirados en **OWASP ASVS**. Esto se traduce en funcionalidades concretas como autenticación robusta, políticas de contraseñas, sesiones seguras, validación estricta de entradas, carga controlada de archivos, auditoría de eventos, control de acceso por roles, respaldos periódicos y procedimientos de recuperación.

Para el GADPR-LM, el sistema aportará beneficios institucionales directos: reducción del tiempo de consulta documental, mejora en la trazabilidad de trámites, fortalecimiento del control administrativo, disminución del riesgo operativo y mejor preparación para procesos de control interno, auditoría y rendición de cuentas. En términos de madurez organizacional, permitirá pasar de una lógica documental reactiva y manual a una operación digitalizada, ordenada y sustentada en reglas verificables.

---

3. Antecedentes y problemática

En numerosas instituciones públicas, la gestión documental se desarrolla todavía con prácticas mixtas: archivos físicos en carpetas o archivadores, documentos digitales almacenados en computadoras individuales, unidades compartidas o memorias externas, registros manuales en hojas de cálculo y mecanismos de control informal basados en conocimiento tácito del personal. Esta situación suele generar dependencia de personas específicas, inconsistencia en nombres de archivos, dificultad para ubicar información histórica y ausencia de evidencia verificable sobre el tratamiento dado a cada documento.

En el caso del GADPR-LM, la necesidad de un sistema especializado se justifica por la coexistencia probable de varios riesgos operativos y de seguridad:

- pérdida o extravío de documentos digitalizados por almacenamiento no estructurado;
- duplicidad de archivos con diferentes nombres o versiones no controladas;
- exposición de información a personal no autorizado por compartir carpetas sin segmentación;
- inexistencia de una clasificación documental homogénea por tipo, serie y subserie;
- dificultad para determinar quién registró, consultó, modificó o descargó un documento;
- procesos lentos de búsqueda y respuesta a requerimientos internos o externos;
- ausencia de políticas sistematizadas de respaldo, restauración y conservación;
- debilidad en los controles de acceso y manejo de credenciales;
- imposibilidad de contar con evidencia confiable para auditorías o revisiones internas.

La problemática no es únicamente tecnológica. También es funcional, archivística y de seguridad. Sin un sistema formal, la institución no puede garantizar plenamente la autenticidad del documento digital, la integridad de sus metadatos, la fiabilidad del historial de acciones ni la disponibilidad controlada de la información. El resultado es un entorno administrativo vulnerable a retrasos, errores, reprocesos y contingencias.

La digitalización institucional no debe entenderse solo como escanear archivos, sino como implantar un sistema de gestión documental con reglas, catálogos, responsabilidades, permisos,

trazabilidad y respaldo. Por ello, este expediente plantea una solución integral, no un simple repositorio de archivos.

---

4. Justificación técnica

4.1 Justificación institucional

La institución requiere un sistema que respalde su operación documental con orden, transparencia y capacidad de control. Una entidad pública produce, recibe y conserva documentos que sustentan actos administrativos, decisiones, trámites, comunicaciones internas, resoluciones, informes, contratos, oficios y evidencias de gestión. La falta de control sobre dichos documentos afecta directamente la continuidad operativa y la capacidad de respuesta institucional.

4.2 Justificación operativa

La solución permitirá estandarizar el registro documental, reducir tiempos de búsqueda, evitar reprocesos, mejorar la coordinación entre áreas y disminuir la dependencia de conocimientos informales. También facilitará el seguimiento de estados, responsables y movimientos, haciendo visible el ciclo de vida documental de principio a fin.

4.3 Justificación tecnológica

Desde el punto de vista técnico, una aplicación web en intranet ofrece centralización, mantenimiento simplificado, acceso controlado desde equipos institucionales y mejor gobernanza de la información. La separación por capas, la base de datos relacional y el repositorio documental estructurado permiten una solución mantenible, extensible y auditable.

4.4 Justificación documental

El sistema implementará principios de clasificación, conservación, autenticidad, integridad, trazabilidad y usabilidad documental. Esto permitirá que los documentos no sean solamente archivos adjuntos, sino registros institucionales gestionados bajo criterios archivísticos.

4.5 Justificación de seguridad de la información

La información documental institucional puede contener datos internos, reservados o sensibles. Por ello, el sistema necesita incorporar controles de acceso, gestión de identidades, sesiones seguras, bitácoras, mecanismos de respaldo y procedimientos de recuperación. La adopción de principios alineados con ISO/IEC 27001:2022 y OWASP ASVS reduce la exposición a incidentes de seguridad y mejora la capacidad de control interno.

4.6 Justificación por cumplimiento de estándares

La aplicación práctica de ISO 15489 permitirá que el tratamiento documental responda a criterios de autenticidad, integridad, fiabilidad y recuperabilidad. La alineación con ISO/IEC

27001:2022 fortalecerá la gestión segura de activos informacionales, mientras que OWASP ASVS aportará una guía concreta de verificación de requisitos de seguridad para aplicaciones web.

4.7 Justificación de eficiencia administrativa

Una gestión documental digitalizada bien diseñada incrementa la eficiencia administrativa, acorta tiempos de respuesta, facilita el trabajo interáreas y mejora la calidad de los reportes. Además, ayuda a preparar la institución para procesos de auditoría, control interno y mejora continua.

---

5. Objetivo general y objetivos específicos

5.1 Objetivo general

Diseñar y estructurar técnicamente una aplicación web institucional para la gestión documental digitalizada del GADPR-LM, basada en principios archivísticos y controles de seguridad alineados con ISO/IEC 27001:2022, ISO 15489 y OWASP ASVS, que permita registrar, clasificar, consultar, proteger y auditar documentos institucionales de manera controlada y trazable.

5.2 Objetivos específicos

1. Levantar y formalizar los requerimientos funcionales, no funcionales, operativos y de seguridad del sistema.
2. Definir la arquitectura tecnológica, lógica y física más adecuada para operar en intranet institucional.
3. Diseñar el modelo de datos relacional que soporte usuarios, permisos, clasificación documental, archivos, versiones, historial, auditoría, sesiones y respaldos.
4. Especificar los módulos, pantallas, formularios, botones, validaciones y flujos de negocio del sistema desde el acceso inicial hasta la administración y consulta documental.
5. Incorporar controles de autenticación, autorización, validación de entradas, gestión segura de sesiones y registro de eventos de seguridad.
6. Establecer mecanismos de clasificación, indexación, trazabilidad y control de versiones documentales.
7. Definir pruebas funcionales, de seguridad y de validación para asegurar la calidad del producto antes de su puesta en marcha.
8. Proponer un plan de implementación, mantenimiento, respaldo y recuperación acorde con el entorno institucional.
9. Generar una base documental de referencia que pueda ser utilizada por analistas, desarrolladores, docentes, autoridades y responsables institucionales durante el ciclo de vida del proyecto.

Ajuste académico adicional: además de los objetivos funcionales y técnicos, el proyecto de tesis debe permitir evidenciar la relación entre el problema institucional identificado, la propuesta tecnológica formulada y los resultados esperados en términos de mejora de organización documental, seguridad y trazabilidad.

6. Alcance del sistema

6.1 Alcance funcional incluido

El sistema sí incluirá:

- autenticación de usuarios y recuperación controlada de credenciales;
- administración de usuarios, roles, permisos, cargos y dependencias;
- mantenimiento de catálogos documentales: tipos, series, subseries y clasificaciones;
- registro de documentos con metadatos obligatorios;
- carga segura de archivos digitalizados;
- indexación documental;
- consulta y búsqueda avanzada;
- visualización y descarga controlada de documentos;
- control de versiones;
- administración de estados del trámite documental;
- historial de movimientos y trazabilidad;
- bitácora de auditoría;
- reportes administrativos y operativos;
- gestión de sesiones;
- configuración general del sistema;
- respaldo y recuperación.

6.2 Límites funcionales

No se considera en el alcance base:

- firma electrónica avanzada integrada;
- interoperabilidad completa con plataformas externas gubernamentales;
- OCR avanzado con inteligencia artificial como requisito obligatorio;
- flujos BPM complejos de varias instituciones;
- gestión de expedientes ciudadanos externos con portal público;
- integración con Active Directory, salvo que se apruebe como ampliación;
- notificaciones móviles o acceso desde internet público sin VPN.

6.3 Límites técnicos

- Operación prevista principalmente en intranet.
- Arquitectura orientada a una única institución con multiárea interno.
- Escalabilidad básica y modular, no masiva internet-first.

- Almacenamiento documental en repositorio institucional controlado.
- Base de datos relacional centralizada.

6.4 Límites operativos

- La calidad de los metadatos dependerá de la disciplina de carga y validación institucional.
- La digitalización física de documentos requerirá lineamientos operativos complementarios.
- La clasificación documental final deberá ser validada por responsables de archivo o secretaría institucional.

---

7. Marco normativo y técnico aplicable

7.1 ISO/IEC 27001:2022 aplicada al sistema

La norma orienta a establecer controles para proteger activos de información. En este proyecto se traduce en decisiones concretas:

- **Control de acceso:** el sistema implementará roles, permisos y alcance por dependencia. Un usuario solo podrá consultar, editar o descargar documentos dentro de su ámbito autorizado.
- **Gestión de identidades:** cada usuario tendrá cuenta única, estado, historial de acceso y asignación explícita de roles.
- **Autenticación:** se exigirá credencial segura, política de contraseñas, bloqueo por intentos fallidos y posibilidad de segundo factor para perfiles críticos.
- **Segregación de funciones:** se separarán funciones administrativas, operativas y de auditoría para evitar conflictos de interés.
- **Registro de eventos:** todo acceso, cambio de estado, edición de metadatos, descarga y evento crítico quedará registrado.
- **Respaldo:** se programarán copias de seguridad de base de datos y repositorio documental, con validación de restauración.
- **Gestión segura de la información:** se protegerá el almacenamiento, la transmisión interna, los errores, la exposición de datos y el manejo de incidentes.

7.2 ISO 15489 aplicada al sistema

La gestión documental no se limita al archivo físico o digital, sino a garantizar que el documento mantenga su valor como evidencia institucional. En el sistema esto se materializa en:

- **Autenticidad:** cada documento tendrá origen, responsable, fecha, clasificación y evidencia de quién lo registró.
- **Integridad:** los archivos se almacenarán con hash de verificación y no serán sustituidos silenciosamente.

- **Fiabilidad:** los metadatos obligatorios permitirán que el documento sea entendible y utilizable en contexto.
- **Usabilidad:** la búsqueda y visualización controlada facilitarán el acceso al documento correcto cuando sea necesario.
- **Clasificación:** se aplicarán tipos documentales, series y subseries para ordenar el repositorio.
- **Conservación:** se contemplarán plazos, estados y criterios de archivo lógico.
- **Trazabilidad:** se mantendrá histórico de versiones, movimientos y eventos relevantes.

7.3 OWASP ASVS aplicado al sistema

OWASP ASVS sirve como referencia de verificación de seguridad de aplicaciones. En este proyecto se traduce en controles específicos:

- **Autenticación:** credenciales robustas, recuperación segura y protección contra enumeración de usuarios.
- **Gestión de sesiones:** cookies seguras, expiración por inactividad, revocación y protección contra secuestro de sesión.
- **Validación de entradas:** filtros estrictos en formularios, parámetros y cargas de archivos.
- **Control de acceso:** verificación en backend de cada acción, sin confiar en ocultamiento de botones en frontend.
- **Protección de datos:** minimización de exposición de datos sensibles y manejo adecuado de errores.
- **Registros de auditoría:** eventos relevantes registrados sin revelar información crítica al usuario final.
- **Manejo de errores:** mensajes controlados, sin stack traces ni detalles internos en interfaz.
- **Almacenamiento seguro:** archivos fuera del webroot, hashes, permisos de acceso y validación de tipos reales.
- **Protección contra ataques comunes:** mitigación de inyección, XSS, CSRF, subida maliciosa de archivos, fuerza bruta y referencias directas inseguras.

7.4 Traducción del marco normativo a funcionalidades

Norma / referencia	Exigencia práctica	Funcionalidad concreta en el sistema
ISO/IEC 27001:2022	Control de acceso	Módulo de usuarios, roles, permisos y segmentación por dependencia
ISO/IEC 27001:2022	Registro de eventos	Bitácora de auditoría, historial documental y sesiones
ISO/IEC 27001:2022	Respaldo y disponibilidad	Módulo de respaldos, validación y restauración
ISO 15489	Autenticidad documental	Registro con responsable,

Norma / referencia	Exigencia práctica	Funcionalidad concreta en el sistema
		fecha, clasificación y trazabilidad
ISO 15489	Integridad documental	Hash del archivo, control de versiones y bloqueo de sobreescritura
ISO 15489	Organización y recuperación	Tipos, series, subseries, indexación y búsqueda avanzada
OWASP ASVS	Validación y manejo seguro de sesiones	Sanitización, cookies seguras, CSRF, expiración y control de acceso en backend
OWASP ASVS	Seguridad de carga de archivos	Validación MIME, tamaño, antivirus, repositorio aislado

8. Metodología de desarrollo recomendada

8.1 Metodología recomendada: enfoque híbrido incremental con gestión ágil tipo Scrum

Se recomienda una **metodología híbrida incremental**, combinando: - una fase inicial de **análisis y diseño formal** por tratarse de una institución pública y un sistema sensible; y - una ejecución **ágil por iteraciones tipo Scrum**, para construir módulos priorizados, validarlos con usuarios y ajustar tempranamente.

Esta combinación es adecuada porque el proyecto requiere trazabilidad documental, control de cambios, entregables verificables y validación periódica con la institución.

8.2 Fases propuestas

1. **Inicio y diagnóstico**
   - revisión de procesos actuales;
   - identificación de usuarios, áreas y volumen documental;
   - confirmación de supuestos.
2. **Levantamiento y análisis**
   - requerimientos funcionales y no funcionales;
   - reglas de negocio;
   - clasificación documental base;
   - mapa de actores.
3. **Diseño**
   - arquitectura;
   - base de datos;

  - prototipos de interfaz;
  - modelo de seguridad;
  - diseño de pruebas.
4. **Construcción iterativa**
  - Sprint 1: acceso, usuarios, roles, dependencias;
  - Sprint 2: catálogos documentales y registro;
  - Sprint 3: carga de archivos, indexación, consulta;
  - Sprint 4: estados, versiones, historial;
  - Sprint 5: auditoría, reportes, configuración, respaldos.
5. **Pruebas integrales**
  - funcionales;
  - seguridad;
  - permisos;
  - rendimiento básico;
  - restauración.
6. **Implementación**
  - despliegue en intranet;
  - capacitación;
  - datos iniciales;
  - salida a producción.
7. **Estabilización y mejora**
  - soporte;
  - correcciones;
  - monitoreo;
  - backlog evolutivo.

8.3 Roles sugeridos del proyecto

Rol	Responsabilidad principal
Patrocinador institucional	Aprobación estratégica, disponibilidad de recursos y validación de alcance
Product Owner institucional	Priorizar requerimientos y validar entregables funcionales
Analista funcional	Levantar procesos, reglas y necesidades operativas
Arquitecto de software	Definir arquitectura, stack, seguridad y decisiones técnicas
Desarrollador backend	Implementar reglas, API, seguridad y persistencia
Desarrollador frontend	Construir interfaces, navegación y validaciones cliente
DBA	Diseñar y optimizar el modelo de datos

Rol	Responsabilidad principal
QA / Tester	Diseñar y ejecutar pruebas
Especialista de seguridad	Revisar controles, hardening y cumplimiento
Responsable documental	Validar clasificaciones, series y reglas archivísticas

8.4 Artefactos de trabajo

- expediente técnico;
- backlog priorizado;
- historias de usuario;
- casos de uso;
- prototipos;
- diagrama arquitectónico;
- modelo de datos;
- matriz de roles y permisos;
- plan de pruebas;
- manual técnico;
- manual de usuario;
- plan de despliegue.

8.5 Cronograma sugerido por etapas

Etapa	Duración sugerida	Entregable principal
Diagnóstico y levantamiento	2 a 3 semanas	Documento de requerimientos y validación de supuestos
Diseño técnico y base de datos	2 semanas	Arquitectura, prototipos y modelo de datos
Construcción iterativa	8 a 10 semanas	Módulos funcionales por sprint
Pruebas integrales y ajustes	2 a 3 semanas	Evidencias de pruebas y correcciones
Implementación y capacitación	1 a 2 semanas	Sistema desplegado y personal capacitado

9. Levantamiento y análisis de requerimientos

9.1 Requerimientos funcionales

A continuación se plantean requerimientos funcionales numerados y explicados.

- RF-01. El sistema debe permitir autenticación de usuarios mediante credenciales institucionales seguras.
- RF-02. El sistema debe permitir recuperación controlada de contraseña mediante token temporal.
- RF-03. El sistema debe administrar usuarios con estados: activo, bloqueado, suspendido e inactivo.
- RF-04. El sistema debe permitir asociar usuarios a una o varias dependencias según política institucional.
- RF-05. El sistema debe permitir crear, editar, activar e inactivar roles.
- RF-06. El sistema debe permitir asignar permisos por rol y por acción funcional.
- RF-07. El sistema debe registrar dependencias o áreas institucionales y su jerarquía.
- RF-08. El sistema debe registrar cargos institucionales para asociarlos a usuarios.
- RF-09. El sistema debe mantener un catálogo de tipos documentales.
- RF-10. El sistema debe mantener catálogos de series y subseries documentales.
- RF-11. El sistema debe permitir registrar documentos con metadatos obligatorios y opcionales.
- RF-12. El sistema debe permitir guardar documentos en estado borrador cuando aún no se complete la carga documental.
- RF-13. El sistema debe permitir cargar archivos digitalizados o electrónicos asociados a un documento.
- RF-14. El sistema debe validar extensión, tipo MIME real, tamaño máximo y seguridad del archivo antes de almacenarlo.
- RF-15. El sistema debe calcular y almacenar un hash de integridad por archivo cargado.
- RF-16. El sistema debe permitir indexar documentos con palabras clave, remitente, destinatario y referencias cruzadas.
- RF-17. El sistema debe permitir búsqueda simple y avanzada por múltiples filtros.
- RF-18. El sistema debe permitir visualización controlada de documentos y metadatos.
- RF-19. El sistema debe permitir descarga de documentos únicamente a usuarios autorizados.
- RF-20. El sistema debe permitir registrar nuevas versiones de un documento conservando historial completo.
- RF-21. El sistema debe administrar estados documentales y sus transiciones autorizadas.
- RF-22. El sistema debe mantener un historial cronológico de eventos por documento.
- RF-23. El sistema debe registrar bitácora de auditoría de acciones relevantes de usuarios y sistema.
- RF-24. El sistema debe generar reportes por dependencia, tipo, estado, fecha y actividad.
- RF-25. El sistema debe administrar configuración general de políticas y parámetros del sistema.
- RF-26. El sistema debe ejecutar y registrar respaldos de base de datos y repositorio documental.
- RF-27. El sistema debe permitir restauración controlada de respaldos por personal autorizado.
- RF-28. El sistema debe gestionar sesiones activas y permitir cierre remoto de sesiones.

- RF-29. El sistema debe registrar intentos fallidos de acceso y aplicar bloqueo temporal según política.
- RF-30. El sistema debe registrar justificación cuando un usuario descargue o consulte documentos restringidos, si la política lo exige.
- RF-31. El sistema debe exportar reportes a PDF, Excel o CSV según permisos.
- RF-32. El sistema debe permitir marcar documentos como archivados sin perder posibilidad de consulta autorizada.
- RF-33. El sistema debe permitir relacionar documentos entre sí como anexos, referencias o antecedentes.
- RF-34. El sistema debe notificar eventos críticos, como respaldos fallidos o bloqueos de cuenta, a perfiles administrativos definidos.
- RF-35. El sistema debe impedir la eliminación física de documentos operativos sin un procedimiento especial de retención y autorización.

9.2 Requerimientos no funcionales

Seguridad

- RNF-01. Toda solicitud sensible debe verificarse en backend independientemente de lo que muestre la interfaz.
- RNF-02. Las contraseñas deben almacenarse mediante algoritmo de hash robusto con sal.
- RNF-03. La sesión debe expirar por inactividad y debe poder revocarse.
- RNF-04. El sistema no debe exponer trazas internas en pantalla.
- RNF-05. La carga de archivos debe ejecutarse con validaciones de seguridad y almacenamiento fuera del directorio público.

Rendimiento

- RNF-06. Las consultas comunes deben responder en tiempos razonables dentro de la intranet institucional.
- RNF-07. La búsqueda avanzada debe usar índices y paginación.
- RNF-08. Las operaciones pesadas como respaldos o exportaciones grandes deben poder ejecutarse de forma controlada.

Usabilidad

- RNF-09. La interfaz debe ser coherente, clara y navegable por perfiles administrativos.
- RNF-10. Los formularios deben mostrar ayudas, mensajes de validación y confirmaciones comprensibles.
- RNF-11. El sistema debe minimizar clics innecesarios en procesos frecuentes.

Disponibilidad y resiliencia

- RNF-12. El sistema debe poder restaurarse a partir de respaldos verificados.
- RNF-13. Debe existir monitoreo básico de servicios críticos.
- RNF-14. La arquitectura debe separar datos, lógica y almacenamiento documental para facilitar recuperación.

Mantenibilidad

- RNF-15. El código debe estructurarse por capas y módulos.
- RNF-16. Debe existir control de versiones del software y documentación técnica actualizada.
- RNF-17. Las configuraciones sensibles deben externalizarse y no quedar embebidas en código fuente.

Compatibilidad

- RNF-18. El sistema debe funcionar correctamente en navegadores institucionales modernos.
- RNF-19. Debe contemplar diseño adaptable a diferentes resoluciones de escritorio.

Trazabilidad y auditoría

- RNF-20. Toda acción crítica debe quedar asociada a usuario, fecha, hora, resultado e identificador del recurso afectado.
- RNF-21. Las modificaciones relevantes deben conservar valores anteriores y posteriores o, al menos, una descripción suficiente del cambio.

Restricciones de intranet

- RNF-22. El sistema debe poder operar sin depender permanentemente de servicios públicos externos.
- RNF-23. Debe permitir configuración de rutas de almacenamiento y políticas internas del servidor institucional.

---

10. Identificación de actores del sistema

10.1 Administrador del sistema

Responsabilidades: administrar usuarios, roles, parámetros, catálogos maestros, políticas de seguridad, respaldos y monitoreo general.
Permisos típicos: acceso total a administración; acceso restringido al contenido documental según necesidad operativa.
Restricciones: no debería aprobar todos los procesos documentales operativos si la segregación de funciones lo impide.
Acciones permitidas: crear usuarios, bloquear cuentas, configurar políticas, ejecutar respaldos, revisar auditoría, cerrar sesiones remotas.

10.2 Secretario/a o gestor documental

Responsabilidades: registrar documentos, digitalizar, cargar archivos, indexar, clasificar, actualizar estados y controlar versiones.
Permisos típicos: creación, edición y consulta de documentos de su ámbito; generación de reportes operativos.
Restricciones: no puede alterar roles ni configuraciones globales.

Acciones permitidas: registrar documento, completar metadatos, cargar archivos, corregir clasificación, consultar historial.

10.3 Usuario institucional

Responsabilidades: consultar documentos autorizados, registrar solicitudes documentales o documentos básicos si la política lo permite.
Permisos típicos: consulta, visualización y descarga limitada.
Restricciones: no administra catálogos ni seguridad.
Acciones permitidas: buscar, ver, descargar según autorización, cambiar contraseña, revisar sus sesiones.

10.4 Auditor interno

Responsabilidades: revisar trazabilidad, accesos, integridad operativa y cumplimiento de controles.
Permisos típicos: acceso a bitácora, historial, reportes de auditoría y evidencias de respaldo.
Restricciones: no modifica contenido operativo salvo observaciones documentadas.
Acciones permitidas: consultar auditoría, exportar evidencias, revisar eventos críticos.

10.5 Supervisor o autoridad

Responsabilidades: revisar indicadores, autorizar transiciones o cierres, consultar reportes y supervisar áreas.
Permisos típicos: consulta amplia del ámbito autorizado, aprobación/rechazo según flujo.
Restricciones: no administra infraestructura ni seguridad técnica.
Acciones permitidas: aprobar estados, revisar reportes gerenciales, consultar carga documental y actividad.

---

11. Arquitectura general del sistema

11.1 Pila tecnológica recomendada

Considerando el contexto real indicado para la tesis, se recomienda la siguiente pila tecnológica base:

- **Frontend:** interfaz web renderizada en servidor con Blade o vistas PHP estructuradas, complementada con Bootstrap 5, JavaScript y componentes responsivos para entorno institucional.
- **Backend: Laravel 10/11 sobre PHP 8.2+**, ejecutado en **Apache** mediante **XAMPP**, con arquitectura MVC, middlewares de seguridad, validaciones de formularios, control de sesiones y gestión de permisos por rol.
- **Base de datos: MySQL/MariaDB administrada desde XAMPP** (phpMyAdmin para administración y scripts SQL para despliegue controlado).

- **Almacenamiento documental:** repositorio estructurado en carpetas protegidas del servidor, fuera del directorio público de Apache, con rutas controladas desde la aplicación.
- **Servidor de aplicaciones:** estación o servidor institucional con Windows y XAMPP como entorno de ejecución del prototipo, piloto o despliegue inicial de tesis.
- **Publicación temporal / pruebas externas: ngrok** para exponer de forma temporal el sistema local durante validaciones, demostraciones, revisión por parte de tutores o pruebas fuera de la red local.
- **Autenticación:** autenticación basada en sesión segura de Laravel/PHP, con hash robusto de contraseñas, expiración por inactividad, regeneración de sesión y controles de bloqueo.
- **Auditoría y logs:** bitácora en base de datos + registros de aplicación en archivos protegidos del servidor.
- **Reportes:** generación server-side a PDF, Excel y CSV.
- **Respaldo:** exportación de base de datos MySQL/MariaDB, copia de repositorio documental y bitácoras de respaldo.

11.2 Justificación técnica de la pila

La elección de **Laravel + PHP + Apache + MySQL/MariaDB sobre XAMPP** responde a criterios de viabilidad académica, facilidad de despliegue, disponibilidad de herramientas, curva de aprendizaje razonable y coherencia con entornos de tesis desarrollados en infraestructura local.

1. **Adecuación al entorno real del proyecto:** al haberse definido XAMPP como entorno de conexión y operación, resulta técnicamente coherente usar Apache, PHP y MySQL/MariaDB dentro de dicho stack.
2. **Rapidez de implementación:** Laravel acelera la construcción de autenticación, validaciones, migraciones, controladores, middlewares, políticas de autorización y gestión documental.
3. **Mantenibilidad:** el patrón MVC facilita separar vistas, lógica de negocio y acceso a datos.
4. **Compatibilidad institucional:** XAMPP funciona apropiadamente en equipos Windows utilizados con frecuencia en instituciones públicas y contextos académicos.
5. **Soporte para pruebas y defensa de tesis:** ngrok permite compartir temporalmente el sistema hospedado localmente sin requerir una infraestructura pública permanente.
6. **Seguridad razonable para prototipo y piloto:** la combinación Laravel + Apache + MySQL/MariaDB permite aplicar controles alineados con OWASP ASVS, ISO/IEC 27001:2022 e ISO 15489.
7. **Escalabilidad progresiva:** aunque el proyecto inicie en XAMPP, la arquitectura puede migrar más adelante a un servidor Linux o Windows endurecido sin rediseñar completamente la solución.

11.3 Arquitectura por capas

1. **Capa de presentación**

  - interfaz web;
  - formularios;
  - paneles;
  - navegación por rol;
  - validaciones de usabilidad.
2. **Capa de aplicación**
  - casos de uso;
  - orquestación de procesos;
  - validaciones funcionales;
  - transiciones de estado;
  - control de permisos.
3. **Capa de dominio**
  - entidades principales;
  - reglas de negocio;
  - políticas documentales;
  - servicios de seguridad;
  - políticas de versionado y clasificación.
4. **Capa de infraestructura**
  - acceso a base de datos;
  - repositorio de archivos;
  - correo/notificaciones;
  - logs;
  - jobs de respaldo;
  - integración con antivirus o verificación externa si aplica.

11.4 Arquitectura lógica

```
Usuario institucional
    |
    v
Navegador web institucional
    |
    v
Apache (XAMPP)
    |
    v
Aplicación Laravel / PHP
    |---------------------> Módulo de autenticación y sesiones
    |---------------------> Módulo de gestión documental
    |---------------------> Módulo de reportes
    |---------------------> Módulo de auditoría
    |
    +---------------------> MySQL/MariaDB (XAMPP)
```

```
    |
    +----------------------> Repositorio documental seguro
    |
    +----------------------> Servicio de respaldos
```

11.5 Arquitectura física en intranet

```
[PC institucionales]
    |
    v
[Switch / red local]
    |
    v
[Servidor o equipo institucional con Windows + XAMPP]
    |            |              |
    |            |              |
    v            v              v
[Apache/PHP]    [MySQL/MariaDB]    [Repositorio documental]
    |
    v
[Acceso interno por intranet]
```

Acceso temporal externo controlado:
[ngrok tunnel HTTPS] -> [Apache/PHP en equipo local o servidor piloto]

Aclaración técnica sobre ngrok: ngrok se plantea como mecanismo de exposición temporal y controlada para pruebas, revisión remota por tutores, validación funcional o demostraciones del proyecto de tesis. **No se considera mecanismo de producción definitiva** para la institución.

11.6 Flujo de interacción entre componentes

1. El usuario accede a la URL interna del sistema o, durante pruebas controladas, al enlace temporal generado por ngrok.
2. Apache, ejecutado sobre XAMPP, recibe la solicitud HTTP/HTTPS.
3. Laravel procesa la ruta solicitada y ejecuta middlewares de seguridad.
4. Si el usuario no está autenticado, se redirige al login.
5. El sistema valida credenciales contra la tabla de usuarios en MySQL/MariaDB.
6. Si la autenticación es exitosa, se crea o regenera una sesión segura.
7. Se cargan roles, permisos y alcance documental del usuario.
8. El usuario accede al módulo requerido.
9. Cada formulario enviado se valida en cliente y servidor.
10. Los metadatos documentales se almacenan en MySQL/MariaDB.
11. Los archivos digitales se guardan en el repositorio documental protegido del servidor.
12. Cada operación crítica se registra en la tabla de auditoría.

13. Los reportes consultan vistas, tablas o filtros del sistema y generan archivos descargables.
14. Los respaldos se ejecutan mediante tareas programadas sobre base de datos y archivos.
15. Cuando la prueba externa finaliza, el túnel ngrok debe cerrarse y registrarse en bitácora administrativa.

---

12. Diseño completo del sistema por módulos

12.1 Flujo general del sistema desde el inicio

1. El usuario accede a la URL interna del sistema.
2. Se presenta la pantalla splash con identidad institucional y verificación inicial.
3. Si existe una sesión válida, el sistema redirige al dashboard según rol.
4. Si no existe sesión, se muestra el formulario de inicio de sesión.
5. El usuario ingresa credenciales y, si corresponde, un factor adicional.
6. El backend valida usuario, contraseña, estado, permisos y políticas.
7. Si la validación es correcta, se registra el evento de acceso y se crea la sesión.
8. El dashboard carga indicadores y accesos rápidos según perfil.
9. El usuario navega por menús laterales y barra superior.
10. En el módulo documental puede registrar, clasificar, indexar, consultar, visualizar, versionar o cambiar estados según permisos.
11. Cada acción importante genera un registro de trazabilidad o auditoría.
12. El usuario puede generar reportes, revisar historial y administrar sus sesiones.
13. Finalmente puede cerrar sesión manualmente o el sistema lo hará por inactividad.

12.2.1 Splash o pantalla inicial

Objetivo: Presentar la identidad institucional, verificar disponibilidad básica del sistema y redirigir de forma segura al login o al panel, según exista o no una sesión válida. **Actor principal:** Todos los usuarios **Ruta de acceso sugerida:** /

Descripción funcional: Presentar la identidad institucional, verificar disponibilidad básica del sistema y redirigir de forma segura al login o al panel, según exista o no una sesión válida. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Logotipo institucional:** tipo visual. Validación principal: No editable. - **Nombre del sistema:** tipo texto fijo. Validación principal: No editable. - **Versión del sistema:** tipo texto fijo. Validación principal: Se obtiene desde configuración. - **Indicador de estado:** tipo visual. Validación principal: Muestra conexión con backend. - **Mensaje de carga:** tipo texto fijo. Validación principal: No editable.

Botones y comportamiento exacto: - **Continuar:** Se habilita cuando la verificación inicial concluye correctamente y redirige a login o dashboard. - **Reintentar:** Vuelve a consultar disponibilidad del backend, base de datos y servicio de almacenamiento.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Todos los usuarios. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - No debe exponer errores técnicos detallados. Si el backend no responde, solo muestra un mensaje controlado y registra el evento en monitoreo. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - No almacena datos sensibles; impide enumeración de infraestructura; aplica rate limit sobre las verificaciones si se invoca repetidamente. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.2 Inicio de sesión

Objetivo: Autenticar usuarios autorizados y establecer una sesión segura con controles de expiración, bloqueo y auditoría. **Actor principal:** Administrador, gestor documental, auditor, autoridad, usuario institucional **Ruta de acceso sugerida:** /login

Descripción funcional: Autenticar usuarios autorizados y establecer una sesión segura con controles de expiración, bloqueo y auditoría. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Usuario o correo institucional:** tipo varchar(150). Validación principal: Obligatorio, formato válido, trim y normalización. - **Contraseña:** tipo password. Validación principal: Obligatoria, no visible, máximo 128 caracteres. - **Código OTP:** tipo varchar(10). Validación principal: Opcional si se activa segundo factor. - **Recordar equipo:** tipo boolean. Validación principal: Solo para dispositivos institucionales autorizados.

Botones y comportamiento exacto: - **Ingresar:** Valida credenciales, estado del usuario, vigencia y restricciones; crea sesión y registra acceso. - **Olvidé mi contraseña:** Redirige al flujo de recuperación. - **Mostrar/Ocultar contraseña:** Solo cambia la visualización local del campo.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador, gestor documental, auditor, autoridad, usuario institucional. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - Tras cinco intentos fallidos consecutivos, bloquea temporalmente la cuenta según política. No revela si el usuario existe; usa mensajes genéricos. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Hash Argon2id o bcrypt, cookies HttpOnly, SameSite, expiración por inactividad, CSRF para solicitudes posteriores, registro de IP, agente y hora. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.3 Recuperación de contraseña

Objetivo: Permitir la recuperación controlada del acceso mediante token temporal de un solo uso. **Actor principal:** Usuarios activos **Ruta de acceso sugerida:** /recuperar-acceso

Descripción funcional: Permitir la recuperación controlada del acceso mediante token temporal de un solo uso. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Correo institucional:** tipo varchar(150). Validación principal: Obligatorio, debe existir y estar activo. - **Token de recuperación:** tipo varchar(120). Validación principal: Generado por el sistema. - **Nueva contraseña:** tipo password. Validación principal: Cumple política de complejidad. - **Confirmar contraseña:** tipo password. Validación principal: Debe coincidir con la nueva contraseña.

Botones y comportamiento exacto: - **Enviar solicitud:** Genera token y notificación controlada. - **Validar token:** Comprueba vigencia, uso único y destinatario. - **Actualizar contraseña:** Cambia credencial, invalida sesiones y registra evento.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Usuarios activos. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - El enlace de recuperación expira en un tiempo corto; el sistema invalida enlaces previos al generar uno nuevo. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Token aleatorio fuerte, almacenamiento del hash del token, límite de frecuencia por cuenta e IP, notificación de cambio exitoso. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.4 Dashboard principal

Objetivo: Mostrar un resumen operativo del sistema según permisos, con indicadores, accesos rápidos y alertas. **Actor principal:** Todos los roles autenticados **Ruta de acceso sugerida:** /dashboard

Descripción funcional: Mostrar un resumen operativo del sistema según permisos, con indicadores, accesos rápidos y alertas. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Tarjetas KPI:** tipo visual. Validación principal: Documentos registrados, pendientes, archivados, usuarios activos. - **Alertas:** tipo visual. Validación principal: Sesiones próximas a expirar, respaldos fallidos, documentos incompletos. - **Accesos rápidos:** tipo visual. Validación principal: Enlaces según rol. - **Actividad reciente:** tipo grid. Validación principal: Últimas acciones autorizadas.

Botones y comportamiento exacto: - **Ir a módulo:** Navega al módulo permitido. - **Ver detalle KPI:** Abre consulta filtrada. - **Exportar panel:** Genera PDF o Excel según permisos.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Todos los roles autenticados. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - Cada usuario ve únicamente datos de su ámbito autorizado. El dashboard no debe convertirse en un punto de fuga de información interáreas. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Filtrado por rol, dependencia y clasificación; prevención de cache sensible; auditoría de exportaciones. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.5 Gestión de usuarios

Objetivo: Administrar cuentas, estados, dependencia, cargo, datos de contacto y políticas de acceso. **Actor principal:** Administrador del sistema **Ruta de acceso sugerida:** /seguridad/usuarios

Descripción funcional: Administrar cuentas, estados, dependencia, cargo, datos de contacto y políticas de acceso. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Nombres completos:** tipo varchar(150). Validación principal: Obligatorio. - **Identificación:** tipo varchar(20). Validación principal: Obligatoria, única. - **Correo institucional:** tipo varchar(150). Validación principal: Obligatorio, único. - **Cargo:** tipo FK. Validación principal: Obligatorio. - **Dependencia:** tipo FK. Validación principal: Obligatoria. - **Estado:** tipo enum. Validación principal: Activo, bloqueado, suspendido, inactivo. - **Requiere 2FA:** tipo boolean. Validación principal: Opcional. - **Fecha fin de acceso:** tipo date. Validación principal: Opcional para cuentas temporales.

Botones y comportamiento exacto: - **Nuevo:** Abre formulario vacío. - **Guardar:** Inserta usuario y crea auditoría. - **Editar:** Permite cambios controlados. - **Bloquear:** Deshabilita acceso inmediato. - **Restablecer contraseña:** Dispara proceso seguro de cambio. - **Asignar roles:** Abre matriz de roles por usuario.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador del sistema. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - No se permite eliminar físicamente usuarios con trazabilidad histórica; solo inactivar. El correo y la identificación son únicos. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Control dual para acciones críticas, bitácora completa, ocultamiento parcial de datos personales en listados. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.6 Gestión de roles y permisos

Objetivo: Definir perfiles de acceso y matrices de autorización por módulo, acción y alcance. **Actor principal:** Administrador del sistema **Ruta de acceso sugerida:** /seguridad/roles

Descripción funcional: Definir perfiles de acceso y matrices de autorización por módulo, acción y alcance. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Nombre del rol:** tipo varchar(100). Validación principal: Obligatorio y único. - **Descripción:** tipo varchar(255). Validación principal: Obligatoria. - **Nivel de criticidad:** tipo smallint. Validación principal: Obligatorio. - **Estado:** tipo boolean. Validación principal: Activo/inactivo. - **Permisos:** tipo matriz. Validación principal: Crear, ver, editar, aprobar, descargar, exportar, administrar.

Botones y comportamiento exacto: - **Crear rol:** Registra nuevo perfil. - **Editar rol:** Actualiza definición. - **Clonar rol:** Copia permisos base para acelerar configuración. - **Asignar permisos:** Guarda matriz rol_permiso. - **Desactivar:** Impide nuevas asignaciones.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador del sistema. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - Debe existir segregación de funciones; ningún rol operativo debe concentrar registro, aprobación y eliminación definitiva sin control explícito. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Versionado de permisos, bitácora de cambios y revisión periódica de privilegios. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.7 Gestión de dependencias o áreas institucionales

Objetivo: Registrar la estructura orgánica que delimita la propiedad y el acceso a la documentación. **Actor principal:** Administrador, gestor documental autorizado **Ruta de acceso sugerida:** /catalogos/dependencias

Descripción funcional: Registrar la estructura orgánica que delimita la propiedad y el acceso a la documentación. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Código de dependencia:** tipo varchar(20). Validación principal: Único. - **Nombre:** tipo varchar(150). Validación principal: Obligatorio. - **Sigla:** tipo varchar(20). Validación principal: Opcional. - **Dependencia padre:** tipo FK. Validación principal: Opcional. - **Responsable:** tipo FK usuario. Validación principal: Opcional. - **Estado:** tipo boolean. Validación principal: Activo/inactivo.

Botones y comportamiento exacto: - **Nuevo:** Crea dependencia. - **Guardar:** Valida unicidad. - **Editar:** Actualiza metadatos. - **Ver árbol:** Muestra jerarquía orgánica.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador, gestor documental autorizado. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - No se puede desactivar una dependencia con documentos o usuarios activos sin reasignación previa. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Solo perfiles autorizados pueden modificar la estructura; todos los cambios se auditan. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.8 Gestión de tipos documentales

Objetivo: Mantener el catálogo de tipos documentales para la clasificación primaria. **Actor principal:** Administrador, gestor documental **Ruta de acceso sugerida:** /catalogos/tipos-documentales

Descripción funcional: Mantener el catálogo de tipos documentales para la clasificación primaria. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación

documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Código:** tipo varchar(20). Validación principal: Único. - **Nombre:** tipo varchar(120). Validación principal: Obligatorio. - **Descripción:** tipo varchar(255). Validación principal: Opcional. - **Requiere versión:** tipo boolean. Validación principal: Obligatorio. - **Retención activa:** tipo integer. Validación principal: Opcional. - **Estado:** tipo boolean. Validación principal: Activo/inactivo.

Botones y comportamiento exacto: - **Nuevo:** Inserta tipo documental. - **Guardar:** Valida duplicidad. - **Editar:** Actualiza reglas asociadas. - **Inactivar:** Deshabilita para nuevos registros.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador, gestor documental. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - Todo documento debe asociarse a un tipo documental activo. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Catálogo administrado por personal autorizado; controles de consistencia sobre documentos existentes. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.9 Gestión de series y subseries documentales

Objetivo: Implementar la clasificación archivística mediante series y subseries. **Actor principal:** Administrador, gestor documental **Ruta de acceso sugerida:** /catalogos/series

Descripción funcional: Implementar la clasificación archivística mediante series y subseries. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Serie:** tipo varchar(120). Validación principal: Obligatoria. - **Código serie:** tipo varchar(20). Validación principal: Único. - **Subserie:** tipo varchar(120). Validación principal: Opcional. - **Código subserie:** tipo varchar(20). Validación principal: Único cuando aplique. - **Tipo documental asociado:** tipo FK. Validación principal: Opcional. - **Plazo de conservación:** tipo integer. Validación principal: Opcional.

Botones y comportamiento exacto: - **Nueva serie:** Crea registro principal. - **Nueva subserie:** Asocia subclasificación. - **Guardar:** Persistencia y validación. - **Relacionar tipo:** Vincula tipos documentales.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador, gestor documental. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - La subserie no puede existir sin una serie padre. Los documentos archivísticos deben clasificarse al menos a nivel de serie. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Solo usuarios con atribución archivística pueden alterar el cuadro de clasificación. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.10 Registro de documentos

Objetivo: Crear el expediente digital inicial con metadatos obligatorios antes o junto con la carga del archivo. **Actor principal:** Gestor documental, usuario institucional autorizado **Ruta de acceso sugerida:** /documentos/nuevo

Descripción funcional: Crear el expediente digital inicial con metadatos obligatorios antes o junto con la carga del archivo. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Código interno:** tipo varchar(50). Validación principal: Generado o validado. - **Número de documento:** tipo varchar(50). Validación principal: Obligatorio. - **Asunto:** tipo varchar(255). Validación principal: Obligatorio. - **Descripción:** tipo text. Validación principal: Opcional. - **Fecha del documento:** tipo date. Validación principal: Obligatoria. - **Fecha de registro:** tipo datetime. Validación principal: Automática. - **Dependencia propietaria:** tipo FK. Validación principal: Obligatoria. - **Tipo documental:** tipo FK. Validación principal: Obligatorio. - **Serie:** tipo FK. Validación principal: Obligatoria. - **Subserie:** tipo FK. Validación principal: Opcional. - **Clasificación de acceso:** tipo enum. Validación principal: Público interno, restringido, confidencial. - **Responsable:** tipo FK usuario. Validación principal: Obligatorio. - **Estado inicial:** tipo FK. Validación principal: Obligatorio. - **Palabras clave:** tipo array/text. Validación principal: Opcional. - **Observaciones:** tipo text. Validación principal: Opcional.

Botones y comportamiento exacto: - **Guardar borrador:** Crea documento incompleto con estado Borrador. - **Guardar y cargar archivo:** Crea documento y redirige a carga. - **Cancelar:** Descarta cambios no persistidos. - **Limpiar:** Resetea formulario.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Gestor documental, usuario institucional autorizado. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - No puede quedar en estado Registrado si faltan metadatos obligatorios. El número documental debe respetar formato configurado. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Validación estricta del lado cliente y servidor; control de permisos por dependencia; bitácora de creación. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.11 Carga y digitalización de archivos

Objetivo: Incorporar el archivo digital al registro documental con validaciones de integridad, formato y seguridad. **Actor principal:** Gestor documental, usuario autorizado **Ruta de acceso sugerida:** /documentos/{id}/archivos

Descripción funcional: Incorporar el archivo digital al registro documental con validaciones de integridad, formato y seguridad. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Archivo:** tipo binario. Validación principal: Obligatorio. - **Nombre lógico:** tipo varchar(255). Validación principal: Automático o editable según regla. - **Extensión:** tipo varchar(10). Validación principal: Controlada. - **Tamaño:** tipo integer. Validación principal: Controlado. - **Hash SHA-256:** tipo varchar(64). Validación principal: Generado. - **Resolución:** tipo varchar(20). Validación principal: Opcional para digitalización. - **Origen:** tipo enum. Validación principal: Escaneado, cargado, migrado. - **Observación de digitalización:** tipo text. Validación principal: Opcional.

Botones y comportamiento exacto: - **Seleccionar archivo:** Abre explorador. - **Cargar:** Sube archivo y ejecuta validaciones. - **Eliminar carga temporal:** Descarta archivo no confirmado. - **Confirmar:** Asocia archivo definitivo al documento.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Gestor documental, usuario autorizado. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - Solo se permiten extensiones autorizadas, por ejemplo PDF/A, PDF, TIFF, PNG y JPG, según política. Se bloquean ejecutables y archivos comprimidos inseguros. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Antimalware, validación MIME real, límites de tamaño, cuarentena temporal, hash de integridad, almacenamiento fuera del webroot. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.12 Indexación documental

Objetivo: Completar y validar metadatos de recuperación para optimizar búsqueda, clasificación y trazabilidad. **Actor principal:** Gestor documental **Ruta de acceso sugerida:** /documentos/{id}/indexacion

Descripción funcional: Completar y validar metadatos de recuperación para optimizar búsqueda, clasificación y trazabilidad. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Palabras clave:** tipo texto etiquetado. Validación principal: Opcional. - **Remitente:** tipo varchar(150). Validación principal: Opcional. - **Destinatario:** tipo varchar(150). Validación principal: Opcional. - **Ubicación física de respaldo:** tipo varchar(120). Validación principal: Opcional. - **Nivel de confidencialidad:** tipo enum. Validación principal: Obligatorio. - **Vigencia:** tipo date. Validación principal: Opcional. - **Referencia cruzada:** tipo FK documento. Validación principal: Opcional.

Botones y comportamiento exacto: - **Guardar metadatos:** Actualiza índices. - **Validar:** Comprueba consistencia y obligatoriedad. - **Sugerir términos:** Asiste al operador con catálogos predefinidos.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Gestor documental. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - La indexación debe completarse antes de aprobar el documento para consulta institucional. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Control de taxonomías, restricciones por clasificación y auditoría de cambios en metadatos sensibles. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.13 Consulta y búsqueda avanzada

Objetivo: Permitir recuperación ágil de documentos mediante filtros combinados y búsqueda textual controlada. **Actor principal:** Todos los roles con permiso de consulta **Ruta de acceso sugerida:** /documentos/busqueda

Descripción funcional: Permitir recuperación ágil de documentos mediante filtros combinados y búsqueda textual controlada. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Texto libre:** tipo varchar(255). Validación principal: Opcional. - **Rango de fechas:** tipo date/date. Validación principal: Opcional. - **Dependencia:** tipo FK. Validación principal: Opcional. - **Tipo documental:** tipo FK. Validación principal: Opcional. - **Serie/Subserie:** tipo FK. Validación principal: Opcional. - **Estado:** tipo FK. Validación principal: Opcional. - **Responsable:** tipo FK. Validación principal: Opcional. - **Clasificación:** tipo enum. Validación principal: Opcional. - **Tiene archivo:** tipo boolean. Validación principal: Opcional.

Botones y comportamiento exacto: - **Buscar:** Ejecuta consulta filtrada. - **Limpiar filtros:** Restablece criterios. - **Guardar búsqueda:** Guarda preferencias del usuario. - **Exportar resultados:** Genera listado autorizado.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Todos los roles con permiso de consulta. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - Los resultados se limitan al universo autorizado por rol, dependencia y nivel de clasificación. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Paginación, protección contra inyección, trazabilidad de consultas sensibles, restricciones de exportación. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.14 Visualización de documentos

Objetivo: Mostrar metadatos y archivo asociado sin alterar el registro, preservando trazabilidad de acceso. **Actor principal:** Usuarios autorizados **Ruta de acceso sugerida:** /documentos/{id}/ver

Descripción funcional: Mostrar metadatos y archivo asociado sin alterar el registro, preservando trazabilidad de acceso. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Panel de metadatos:** tipo visual. Validación principal: Solo lectura. - **Visor de PDF/imagen:** tipo visual. Validación principal: Render seguro. - **Historial resumido:** tipo visual. Validación principal: Últimos movimientos. - **Clasificación:** tipo visual. Validación principal: Indicador visible.

Botones y comportamiento exacto: - **Ver archivo:** Carga visor seguro. - **Ver historial:** Abre trazabilidad completa. - **Solicitar edición:** Disponible si el rol no puede editar directamente.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Usuarios autorizados. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - La apertura del documento genera rastro de acceso. Documentos confidenciales pueden requerir justificación de consulta. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Control de autorización en cada solicitud, deshabilitación de caché, marcas de agua opcionales. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.15 Descarga de documentos

Objetivo: Permitir la obtención controlada del archivo cuando la política y el rol lo autorizan. **Actor principal:** Usuarios autorizados **Ruta de acceso sugerida:** /documentos/{id}/descargar

Descripción funcional: Permitir la obtención controlada del archivo cuando la política y el rol lo autorizan. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Formato de salida:** tipo enum. Validación principal: Original o copia de consulta. - **Motivo de descarga:** tipo varchar(255). Validación principal: Opcional u obligatorio según clasificación. - **Aceptación de uso:** tipo boolean. Validación principal: Obligatorio para documentos restringidos.

Botones y comportamiento exacto: - **Descargar:** Entrega archivo autorizado. - **Cancelar:** Cierra diálogo.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Usuarios autorizados. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - No todos los usuarios con visualización tienen permiso de descarga. La descarga de documentos restringidos debe quedar justificada. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Expiración de URL firmada, watermark opcional, conteo de descargas y auditoría completa. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.16 Control de versiones documentales

Objetivo: Gestionar nuevas versiones de un documento sin perder su historial ni el archivo vigente. **Actor principal:** Gestor documental, responsable autorizado **Ruta de acceso sugerida:** /documentos/{id}/versiones

Descripción funcional: Gestionar nuevas versiones de un documento sin perder su historial ni el archivo vigente. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Versión:** tipo varchar(20). Validación principal: Generada. - **Motivo de cambio:** tipo text. Validación principal: Obligatorio. - **Archivo nuevo:** tipo binario. Validación principal: Obligatorio. - **Observación:** tipo text. Validación principal: Opcional. - **Es versión vigente:** tipo boolean. Validación principal: Controlado por sistema.

Botones y comportamiento exacto: - **Nueva versión:** Abre flujo de versionado. - **Guardar versión:** Genera registro en documentos_versiones. - **Marcar vigente:** Actualiza bandera actual. - **Comparar:** Muestra metadatos entre versiones.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Gestor documental, responsable autorizado. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - Nunca se sobrescribe físicamente la versión previa; el sistema conserva histórico y responsable del cambio. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Control de concurrencia, hash por versión, permisos diferenciados para versionar. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.17 Estados del trámite documental

Objetivo: Administrar el ciclo de vida del documento mediante transiciones controladas. **Actor principal:** Gestor documental, supervisor, autoridad **Ruta de acceso sugerida:** /documentos/{id}/estado

Descripción funcional: Administrar el ciclo de vida del documento mediante transiciones controladas. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de

clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Estado actual:** tipo FK. Validación principal: Solo lectura. - **Nuevo estado:** tipo FK. Validación principal: Obligatorio. - **Comentario:** tipo text. Validación principal: Obligatorio según transición. - **Fecha efectiva:** tipo datetime. Validación principal: Automática. - **Responsable de transición:** tipo FK usuario. Validación principal: Automática.

Botones y comportamiento exacto: - **Cambiar estado:** Ejecuta transición válida. - **Aprobar:** Disponible en estados revisables. - **Rechazar:** Devuelve con observación. - **Archivar:** Cierra ciclo operativo cuando cumple reglas.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Gestor documental, supervisor, autoridad. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - No se puede archivar un documento sin archivo principal, clasificación y metadatos mínimos completos. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Matriz de transiciones por rol, firma lógica de responsable y trazabilidad inalterable. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.18 Historial y trazabilidad

Objetivo: Mostrar la secuencia cronológica de eventos relevantes del documento. **Actor principal:** Auditor, supervisor, administrador, propietario del documento según política **Ruta de acceso sugerida:** /documentos/{id}/historial

Descripción funcional: Mostrar la secuencia cronológica de eventos relevantes del documento. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Fecha/hora:** tipo datetime. Validación principal: Automática. - **Acción:** tipo varchar(80). Validación principal: Automática. - **Usuario:** tipo FK. Validación principal: Automática. - **Antes/Después:** tipo json/text. Validación principal: Automática. - **Observación:** tipo text. Validación principal: Opcional.

Botones y comportamiento exacto: - **Filtrar:** Acota por acción o fecha. - **Exportar:** Genera reporte autorizado. - **Ver detalle:** Abre evento completo.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Auditor, supervisor, administrador, propietario del documento según política. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - El historial es de solo lectura y no puede ser editado por usuarios funcionales. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Integridad lógica, control de acceso estricto y retención definida. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.19 Bitácora de auditoría

Objetivo: Concentrar eventos de seguridad, acceso, cambios críticos y operaciones administrativas. **Actor principal:** Auditor interno, administrador con privilegio especial **Ruta de acceso sugerida:** /auditoria

Descripción funcional: Concentrar eventos de seguridad, acceso, cambios críticos y operaciones administrativas. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Evento:** tipo varchar(120). Validación principal: Automático. - **Categoría:** tipo enum. Validación principal: Seguridad, gestión, consulta, respaldo. - **Usuario:** tipo FK. Validación principal: Opcional. - **IP:** tipo varchar(45). Validación principal: Automática. - **Resultado:** tipo enum. Validación principal: Éxito, fallo. - **Detalle:** tipo text/json. Validación principal: Automático. - **Severidad:** tipo enum. Validación principal: Baja, media, alta, crítica.

Botones y comportamiento exacto: - **Buscar:** Filtra eventos. - **Exportar:** Extrae reporte controlado. - **Marcar incidente:** Abre flujo de seguimiento interno.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Auditor interno, administrador con privilegio especial. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - La bitácora debe ser inalterable por usuarios funcionales y con retención mínima definida por política. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Sellado lógico, acceso restringido, alertas sobre eventos críticos y sincronización horaria. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.20 Módulo de reportes

Objetivo: Generar salidas consolidadas para gestión, control y toma de decisiones. **Actor principal:** Administrador, supervisor, auditor, autoridad **Ruta de acceso sugerida:** /reportes

Descripción funcional: Generar salidas consolidadas para gestión, control y toma de decisiones. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Tipo de reporte:** tipo lista. Validación principal: Obligatorio. - **Rango de fechas:** tipo date/date. Validación principal: Opcional. - **Dependencia:** tipo FK. Validación principal: Opcional. - **Estado:** tipo FK. Validación principal: Opcional. - **Formato:** tipo enum. Validación principal: PDF, Excel, CSV. - **Nivel de detalle:** tipo enum. Validación principal: Resumen, detallado.

Botones y comportamiento exacto: - **Generar:** Ejecuta reporte. - **Previsualizar:** Muestra resumen. - **Exportar:** Descarga archivo. - **Programar:** Opcional si se implementa ejecución periódica.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador, supervisor, auditor, autoridad. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - Un usuario solo puede emitir reportes sobre el ámbito al que tiene autorización. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Control de exportación, marcas de agua, límite de volumen y registro de emisiones. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.21 Configuración general del sistema

Objetivo: Centralizar parámetros maestros, políticas y opciones globales. **Actor principal:** Administrador del sistema **Ruta de acceso sugerida:** /configuracion

Descripción funcional: Centralizar parámetros maestros, políticas y opciones globales. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Nombre del sistema:** tipo varchar(120). Validación principal: Obligatorio. - **Tiempo de sesión:** tipo integer. Validación principal: Obligatorio. - **Intentos máximos:** tipo smallint. Validación principal: Obligatorio. - **Tamaño máximo de archivo:** tipo integer. Validación principal: Obligatorio. - **Extensiones permitidas:** tipo texto. Validación principal: Obligatorio. - **Ruta lógica de repositorio:** tipo varchar(255). Validación principal: Obligatoria. - **Formato de código documental:** tipo varchar(100). Validación principal: Opcional. - **Política de contraseña:** tipo json. Validación principal: Obligatoria.

Botones y comportamiento exacto: - **Guardar configuración:** Actualiza parámetros. - **Restaurar valores:** Revierte a perfil institucional. - **Probar repositorio:** Verifica conectividad.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador del sistema. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - Los cambios sensibles deben requerir confirmación reforzada y quedar auditados. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Acceso restringido, validación fuerte, versionado de configuración y respaldo previo a cambios críticos. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.22 Respaldo y recuperación

Objetivo: Gestionar copias de seguridad, verificación y restauración controlada. **Actor principal:** Administrador del sistema, operador técnico autorizado **Ruta de acceso sugerida:** /administracion/respaldos

Descripción funcional: Gestionar copias de seguridad, verificación y restauración controlada. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Tipo de respaldo:** tipo enum. Validación principal: Base de datos, repositorio documental, completo. - **Fecha/hora:** tipo datetime. Validación principal: Automática. - **Ubicación:** tipo varchar(255). Validación principal: Automática. - **Resultado:** tipo enum. Validación principal: Éxito, fallo, parcial. - **Checksum:** tipo varchar(64). Validación principal: Automática. - **Responsable:** tipo FK usuario. Validación principal: Automática. - **Punto de restauración:** tipo varchar(80). Validación principal: Opcional.

Botones y comportamiento exacto: - **Ejecutar respaldo:** Inicia tarea autorizada. - **Verificar respaldo:** Comprueba integridad. - **Restaurar:** Lanza proceso controlado. - **Descargar log:** Obtiene bitácora técnica.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador del sistema, operador técnico autorizado. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - La restauración debe requerir autorización reforzada y, de ser posible, ejecutarse primero en entorno de contingencia. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Cifrado del respaldo, separación de funciones, logs detallados y pruebas periódicas de recuperación. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.23 Gestión de sesiones

Objetivo: Permitir control de sesiones activas y cierre remoto cuando corresponda. **Actor principal:** Administrador, usuario autenticado **Ruta de acceso sugerida:** /mi-cuenta/sesiones

Descripción funcional: Permitir control de sesiones activas y cierre remoto cuando corresponda. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Sesión:** tipo identificador. Validación principal: Automático. - **Dispositivo:** tipo varchar(120). Validación principal: Automático. - **IP:** tipo varchar(45). Validación principal: Automática. - **Inicio:** tipo datetime. Validación principal: Automática. - **Última actividad:** tipo datetime. Validación principal: Automática. - **Estado:** tipo enum. Validación principal: Activa, expirada, cerrada.

Botones y comportamiento exacto: - **Cerrar esta sesión:** Finaliza la sesión actual. - **Cerrar otras sesiones:** Mantiene solo la sesión vigente. - **Refrescar:** Actualiza el listado.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Administrador, usuario autenticado. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - El usuario puede cerrar sus sesiones; el administrador puede cerrar sesiones ajenas por incidente o soporte. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Registro continuo de actividad, expiración por inactividad y revocación inmediata. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

12.2.24 Cierre de sesión seguro

Objetivo: Finalizar la sesión sin dejar credenciales o tokens reutilizables. **Actor principal:** Todo usuario autenticado **Ruta de acceso sugerida:** /logout

Descripción funcional: Finalizar la sesión sin dejar credenciales o tokens reutilizables. Este módulo debe respetar la visibilidad por rol, dependencia y nivel de clasificación documental. El frontend solo orienta la navegación; la autorización real debe verificarse siempre en backend.

Campos / componentes principales: - **Confirmación:** tipo boolean. Validación principal: Opcional en configuración. - **Motivo:** tipo enum. Validación principal: Manual, timeout, cierre remoto.

Botones y comportamiento exacto: - **Cerrar sesión:** Invalida cookies/tokens y redirige al login. - **Cancelar:** Vuelve al sistema.

Permisos por rol: - Acceso permitido únicamente a los perfiles definidos para el módulo: Todo usuario autenticado. - Las acciones de escritura, aprobación, exportación o administración deben validarse adicionalmente por permiso específico.

Reglas de negocio destacadas: - El cierre debe invalidar sesión en servidor y limpiar evidencias temporales del cliente. - Toda operación crítica debe dejar trazabilidad.

Qué se guarda en base de datos: - Registros maestros o transaccionales del módulo, identificadores del usuario ejecutor, fecha/hora, resultado, y cuando aplique cambios antes/después.

Qué se muestra al usuario: - Solo información autorizada según rol, dependencia, clasificación y estado del proceso.

Qué ocurre si hay error: - El sistema muestra un mensaje comprensible y no técnico, mantiene los datos no persistidos cuando sea posible y registra el detalle técnico en logs internos.

Controles de seguridad aplicados: - Revocación de sesión, regeneración de identificadores en próximos accesos y registro de evento. - Validación servidor, control anti-CSRF cuando aplique, manejo de errores controlado y auditoría de acciones relevantes.

13. Diseño detallado de navegación

13.1 Estructura general de navegación

La interfaz debe organizarse en:

- **Barra superior:** nombre del sistema, dependencia activa, usuario autenticado, acceso a perfil, sesiones y cierre de sesión.
- **Panel lateral:** menú principal según rol.
- **Área central:** contenido del módulo.
- **Breadcrumbs:** ruta de navegación contextual.
- **Zona de acciones rápidas:** botones frecuentes del módulo.
- **Pie de página discreto:** versión, soporte y fecha/hora institucional si se requiere.

13.2 Menú principal propuesto

1. Inicio
2. Documentos
    - Nuevo documento

    - Búsqueda avanzada
    - Mis documentos / documentos de mi área
    - Versiones
    - Estados
3. Catálogos
    - Dependencias
    - Tipos documentales
    - Series y subseries
4. Seguridad
    - Usuarios
    - Roles y permisos
    - Sesiones
5. Auditoría y control
    - Historial documental
    - Bitácora
    - Reportes
    - Respaldos
6. Configuración
7. Mi cuenta
8. Cerrar sesión

13.3 Funcionamiento de botones típicos

Botón	Qué valida antes de ejecutar	Qué hace internamente	Resultado esperado
Nuevo	permiso crear y contexto válido	inicializa formulario limpio	usuario puede registrar un nuevo elemento
Guardar	campos obligatorios, formatos, permisos	persiste datos en transacción, genera auditoría	registro creado o actualizado
Editar	permiso editar, estado editable	habilita formulario y carga datos actuales	edición controlada
Eliminar	permiso especial, reglas de dependencia y uso	eliminación lógica o bloqueo según política	registro inactivado o marcado
Buscar	filtros válidos, paginación	ejecuta consulta indexada	listado filtrado
Filtrar	formato de criterios	aplica criterios al listado actual	resultados acotados
Ver detalle	permiso ver	obtiene registro completo	visualización de datos
Cargar archivo	tamaño, extensión,	sube a zona temporal	archivo listo para

Botón	Qué valida antes de ejecutar	Qué hace internamente	Resultado esperado
	MIME, permiso	y valida seguridad	confirmar
Descargar	permiso descargar y política del documento	genera respuesta segura / URL firmada	archivo entregado con trazabilidad
Aprobar	permiso aprobar y reglas de transición	cambia estado y registra responsable	documento aprobado
Rechazar	observación obligatoria si aplica	revierte o mueve a estado observado	documento devuelto
Archivar	metadatos completos y estado válido	marca estado archivado y conserva acceso autorizado	cierre lógico del trámite
Restaurar	permiso especial y justificación	revierte estado o recupera respaldo según contexto	elemento reactivado o restaurado
Exportar PDF	permiso exportar	genera documento renderizado	archivo PDF descargable
Exportar Excel	permiso exportar	genera hoja tabular	archivo Excel descargable
Imprimir	permiso ver	prepara vista imprimible	salida en impresora o PDF local
Cerrar sesión	sesión activa	invalida servidor y cliente	regreso seguro al login

13.4 Navegación por rol

- **Administrador:** menú completo.
- **Gestor documental:** módulos documentales, catálogos operativos y reportes operativos.
- **Usuario institucional:** consulta, visualización, descarga autorizada, mi cuenta.
- **Auditor interno:** auditoría, reportes, historial, consultas autorizadas.
- **Supervisor o autoridad:** dashboard ampliado, reportes, revisión de estados y consultas del ámbito.

14. Flujo de procesos del sistema

14.1 Registro de un documento nuevo

1. El usuario ingresa al módulo “Nuevo documento”.
2. El sistema verifica permiso de creación.
3. Se carga formulario con catálogos activos.

4. El usuario selecciona dependencia, tipo documental, serie y subserie.
5. Ingresa número documental, asunto, fecha y clasificación.
6. El sistema valida campos obligatorios, formato y unicidad donde corresponda.
7. Si el usuario presiona **Guardar borrador**, se crea el registro en estado borrador.
8. Si presiona **Guardar y cargar archivo**, el sistema crea el registro y redirige al módulo de carga.
9. Se registra en historial la acción de creación.
10. El documento queda listo para indexación y archivo asociado.

14.2 Carga del archivo digital

1. El usuario selecciona el documento previamente creado.
2. Accede al módulo de archivos.
3. Elige el archivo desde su equipo institucional.
4. El sistema verifica tamaño, extensión permitida, tipo MIME real y políticas de seguridad.
5. El archivo se carga a un área temporal.
6. Se calcula hash de integridad.
7. Si la validación es correcta, el usuario confirma la asociación.
8. El archivo se mueve al repositorio definitivo estructurado.
9. Se registra el evento en auditoría y en historial documental.

14.3 Clasificación documental

1. El gestor documental abre el módulo de indexación.
2. Revisa los metadatos actuales.
3. Completa serie, subserie, palabras clave y clasificación de acceso si faltan.
4. El sistema valida la consistencia con catálogos activos.
5. Se guardan índices de búsqueda.
6. El documento puede pasar a un estado operativo superior si cumple mínimos.

14.4 Cambio de estado

1. El usuario autorizado abre la ficha del documento.
2. Consulta el estado actual y las transiciones permitidas.
3. Selecciona un nuevo estado válido.
4. Ingresa observación si la transición lo exige.
5. El backend verifica rol, reglas y completitud del documento.
6. Si la transición es válida, actualiza estado.
7. Registra evento en historial y auditoría.
8. Actualiza fecha y responsable de la transición.

14.5 Consulta posterior

1. El usuario accede a búsqueda avanzada.
2. Ingresa uno o varios filtros.

3. El backend aplica segmentación por permisos.
4. Devuelve resultados paginados.
5. El usuario abre el detalle del documento.
6. El sistema registra consulta cuando la política lo exija.
7. El usuario visualiza o descarga según autorización.

14.6 Edición de metadatos

1. Se localiza el documento.
2. El sistema verifica que el estado permita edición.
3. El usuario habilitado modifica solo campos permitidos.
4. El backend valida consistencia.
5. Se actualizan campos y se registra antes/después.
6. Si los cambios afectan la clasificación o el acceso, se exige justificación adicional.

14.7 Generación de reportes

1. El usuario autorizado ingresa al módulo reportes.
2. Selecciona tipo de reporte y filtros.
3. El backend valida permisos de cobertura.
4. Ejecuta consulta optimizada.
5. Presenta vista previa y, si se solicita, genera archivo de salida.
6. Registra la emisión del reporte.

14.8 Auditoría de acciones

1. Toda acción crítica invoca un servicio común de auditoría.
2. Se registran usuario, fecha, IP, tipo de evento, resultado y recurso afectado.
3. En cambios relevantes se guarda resumen del antes/después.
4. La información queda disponible para el módulo de bitácora.
5. Los eventos críticos pueden activar alertas internas.

---

15. Reglas de negocio

1. Todo usuario debe tener al menos un rol activo para acceder al sistema.
2. Un usuario no puede consultar documentos de dependencias no autorizadas.
3. Un documento no puede pasar a estado archivado si carece de metadatos obligatorios.
4. Todo documento debe tener un tipo documental activo.
5. La clasificación por serie documental es obligatoria para documentos institucionales archivables.
6. No se permiten archivos con extensiones no autorizadas.
7. No se permite cargar archivos cuyo tipo MIME real no coincida con la extensión declarada.

8. El nombre lógico del documento debe ajustarse al formato institucional configurado cuando la política lo exija.
9. La eliminación física de documentos no está disponible para perfiles operativos.
10. Toda modificación de metadatos debe dejar trazabilidad.
11. Toda descarga de un documento restringido debe quedar auditada.
12. Toda sesión expira tras un período de inactividad definido por política.
13. Tras múltiples intentos fallidos, la cuenta debe bloquearse temporalmente.
14. Las contraseñas deben cumplir complejidad mínima, historial y vigencia si la política institucional así lo exige.
15. Un rol no debe acumular privilegios incompatibles si la matriz de segregación lo prohíbe.
16. No se puede inactivar una dependencia que mantenga documentos o usuarios activos sin reasignación.
17. Toda nueva versión debe conservar la anterior como histórico.
18. Solo puede existir una versión vigente por documento.
19. Los catálogos inactivos no pueden asignarse a nuevos registros.
20. La visualización de documentos confidenciales puede requerir justificación.
21. El sistema no debe revelar si un usuario específico existe durante el login o recuperación.
22. La restauración de respaldos requiere autorización reforzada y debe quedar auditada.
23. Los eventos de seguridad crítica deben clasificarse por severidad.
24. Los reportes deben respetar el mismo modelo de permisos que las consultas en pantalla.
25. Los datos personales visibles en listados deben minimizarse.
26. Todo documento debe mantener referencia a su dependencia propietaria.
27. Un documento relacionado como antecedente no reemplaza el archivo principal del documento actual.
28. Los cambios de clasificación o confidencialidad deben ser realizados solo por perfiles autorizados.
29. El sistema debe impedir referencias directas inseguras a archivos o documentos.
30. La fecha de registro es automática y no editable por perfiles operativos.

---

16. Diseño de la base de datos

16.1 Modelo conceptual

Las entidades principales del sistema son:

- usuarios;
- roles;
- permisos;
- dependencias;
- cargos;

- tipos documentales;
- series y subseries;
- documentos;
- archivos;
- versiones documentales;
- clasificaciones;
- estados documentales;
- historial documental;
- auditoría;
- sesiones;
- respaldos;
- configuración;
- notificaciones;
- recuperación de credenciales.

Estas entidades se agrupan en cuatro dominios: 1. seguridad y acceso; 2. estructura institucional y catálogos; 3. gestión documental; 4. control, auditoría y continuidad.

16.2 Modelo lógico

- Un usuario pertenece a un cargo y a una dependencia principal.
- Un usuario puede tener varios roles.
- Un rol puede tener varios permisos.
- Un documento pertenece a una dependencia y a un tipo documental.
- Un documento puede pertenecer a una serie y subserie.
- Un documento puede tener varios archivos y varias versiones.
- Un documento tiene un estado actual, pero además múltiples movimientos históricos.
- Toda acción relevante puede generar registros en auditoría.
- Un usuario puede tener múltiples sesiones y múltiples solicitudes de recuperación de credenciales.

16.3 Modelo relacional completo

Tabla: usuarios

Propósito: Almacena las cuentas institucionales que acceden al sistema.

Campo	Tipo	Nulo	Clave	Descripción
id_usuario	BIGSERIAL	No	PK	Identificador único
username	VARCHAR(50)	No	UNQ	Nombre de usuario
nombres	VARCHAR(120)	No		Nombres
apellidos	VARCHAR(12	No		Apellidos

Campo	Tipo	Nulo	Clave	Descripción
	0)			
email	VARCHAR(160)	No	UNQ	Correo institucional
password_hash	VARCHAR(255)	No		Hash de contraseña
estado	VARCHAR(15)	No		Activo/ bloqueado/ inactivo
ultimo_login_at	TIMESTAMP	Sí		Último acceso
id_dependencia	BIGINT	No	FK	Dependencia principal
id_cargo	BIGINT	Sí	FK	Cargo asociado

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: roles

Propósito: Define los perfiles de autorización del sistema.

Campo	Tipo	Nulo	Clave	Descripción
id_rol	BIGSERIAL	No	PK	Identificador
codigo	VARCHAR(30)	No	UNQ	Código interno
nombre	VARCHAR(120)	No		Nombre del rol
descripcion	VARCHAR(300)	Sí		Detalle
estado	VARCHAR(15)	No		Activo/ Inactivo

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: permisos

Propósito: Catálogo de acciones autorizables por módulo y operación.

Campo	Tipo	Nulo	Clave	Descripción
id_permiso	BIGSERIAL	No	PK	Identificador
modulo	VARCHAR(80)	No		Módulo
accion	VARCHAR(80)	No		Acción
descripcion	VARCHAR(300)	Sí		Detalle

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: usuario_rol

Propósito: Relaciona usuarios con roles.

Campo	Tipo	Nulo	Clave	Descripción
id_usuario_rol	BIGSERIAL	No	PK	Identificador
id_usuario	BIGINT	No	FK	Usuario
id_rol	BIGINT	No	FK	Rol
estado	VARCHAR(15)	No		Activo/ Inactivo

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: rol_permiso

Propósito: Relaciona roles con permisos.

Campo	Tipo	Nulo	Clave	Descripción
id_rol_permiso	BIGSERIAL	No	PK	Identificador
id_rol	BIGINT	No	FK	Rol
id_permiso	BIGINT	No	FK	Permiso
permitido	BOOLEAN	No		Indicador de habilitación

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de

conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: dependencias

Propósito: Catálogo de áreas institucionales.

Campo	Tipo	Nulo	Clave	Descripción
id_dependencia	BIGSERIAL	No	PK	Identificador
codigo	VARCHAR(30)	No	UNQ	Código
nombre	VARCHAR(150)	No		Nombre
id_dependencia_padre	BIGINT	Sí	FK	Jerarquía
estado	VARCHAR(15)	No		Activo/Inactivo

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: cargos

Propósito: Catálogo de cargos institucionales.

Campo	Tipo	Nulo	Clave	Descripción
id_cargo	BIGSERIAL	No	PK	Identificador
nombre	VARCHAR(120)	No		Nombre del cargo
descripcion	VARCHAR(300)	Sí		Detalle
estado	VARCHAR(15)	No		Activo/Inactivo

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: tipos_documentales

Propósito: Catálogo de tipos documentales.

Campo	Tipo	Nulo	Clave	Descripción
id_tipo_documental	BIGSERIAL	No	PK	Identificador
codigo	VARCHAR(30)	No	UNQ	Código
nombre	VARCHAR(150)	No		Nombre
descripcion	VARCHAR(300)	Sí		Detalle
estado	VARCHAR(15)	No		Estado

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: series_documentales

Propósito: Series archivísticas institucionales.

Campo	Tipo	Nulo	Clave	Descripción
id_serie	BIGSERIAL	No	PK	Identificador
codigo	VARCHAR(30)	No	UNQ	Código
nombre	VARCHAR(150)	No		Nombre
descripcion	VARCHAR(300)	Sí		Detalle
estado	VARCHAR(15)	No		Estado

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: subseries_documentales

Propósito: Subseries archivísticas vinculadas a una serie.

Campo	Tipo	Nulo	Clave	Descripción
id_subserie	BIGSERIAL	No	PK	Identificador
id_serie	BIGINT	No	FK	Serie padre

Campo	Tipo	Nulo	Clave	Descripción
codigo	VARCHAR(30)	No		Código
nombre	VARCHAR(150)	No		Nombre
estado	VARCHAR(15)	No		Estado

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: clasificaciones

Propósito: Niveles de acceso o sensibilidad documental.

Campo	Tipo	Nulo	Clave	Descripción
id_clasificacion	BIGSERIAL	No	PK	Identificador
nombre	VARCHAR(100)	No		Nombre
descripcion	VARCHAR(300)	Sí		Detalle
nivel	INTEGER	No		Nivel relativo
estado	VARCHAR(15)	No		Estado

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: estados_documento

Propósito: Catálogo del ciclo de vida del documento.

Campo	Tipo	Nulo	Clave	Descripción
id_estado	BIGSERIAL	No	PK	Identificador
nombre	VARCHAR(80)	No		Nombre
descripcion	VARCHAR(300)	Sí		Detalle
orden	INTEGER	No		Orden lógico

Campo	Tipo	Nulo	Clave	Descripción
estado	VARCHAR(15)	No		Estado catálogo

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: documentos

Propósito: Tabla central de metadatos del documento.

Campo	Tipo	Nulo	Clave	Descripción
id_documento	BIGSERIAL	No	PK	Identificador
codigo_unico	VARCHAR(80)	No	UNQ	Código institucional
numero_documento	VARCHAR(60)	Sí		Número del documento
asunto	VARCHAR(250)	No		Asunto
descripcion	TEXT	Sí		Detalle
fecha_documento	DATE	No		Fecha del documento
fecha_registro	TIMESTAMP	No		Fecha de registro
id_dependencia	BIGINT	No	FK	Dependencia propietaria
id_tipo_documental	BIGINT	No	FK	Tipo
id_serie	BIGINT	Sí	FK	Serie
id_subserie	BIGINT	Sí	FK	Subserie
id_clasificacion	BIGINT	No	FK	Clasificación
id_estado_actual	BIGINT	No	FK	Estado actual
id_usuario_creador	BIGINT	No	FK	Usuario creador

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de

conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: documentos_versiones

Propósito: Mantiene el histórico de versiones del documento.

Campo	Tipo	Nulo	Clave	Descripción
id_version	BIGSERIAL	No	PK	Identificador
id_documento	BIGINT	No	FK	Documento
numero_version	INTEGER	No		Número de versión
descripcion_cambio	VARCHAR(300)	Sí		Motivo o resumen
vigente	BOOLEAN	No		Versión actual
id_usuario_registro	BIGINT	No	FK	Responsable

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: archivos

Propósito: Almacena metadatos de archivos físicos asociados.

Campo	Tipo	Nulo	Clave	Descripción
id_archivo	BIGSERIAL	No	PK	Identificador
id_documento	BIGINT	No	FK	Documento
nombre_original	VARCHAR(255)	No		Nombre de origen
nombre_interno	VARCHAR(255)	No		Nombre seguro interno
extension	VARCHAR(20)	No		Extensión
mime_type	VARCHAR(120)	No		Tipo MIME
tamano_bytes	BIGINT	No		Tamaño
hash_sha256	VARCHAR(12	No		Hash

Campo	Tipo	Nulo	Clave	Descripción
	8)			integridad
ruta_almacenamiento	VARCHAR(500)	No		Ruta segura
es_principal	BOOLEAN	No		Indicador principal

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: historial_documento

Propósito: Registra eventos y transiciones del documento.

Campo	Tipo	Nulo	Clave	Descripción
id_historial	BIGSERIAL	No	PK	Identificador
id_documento	BIGINT	No	FK	Documento
id_estado_desde	BIGINT	Sí	FK	Estado origen
id_estado_hasta	BIGINT	Sí	FK	Estado destino
accion	VARCHAR(80)	No		Acción
observacion	TEXT	Sí		Observación
id_usuario	BIGINT	No	FK	Usuario
fecha_evento	TIMESTAMP	No		Fecha/hora

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: auditoria

Propósito: Bitácora transversal de eventos del sistema.

Campo	Tipo	Nulo	Clave	Descripción
id_auditoria	BIGSERIAL	No	PK	Identificador
id_usuario	BIGINT	Sí	FK	Usuario
modulo	VARCHAR(80)	No		Módulo

Campo	Tipo	Nulo	Clave	Descripción
accion	VARCHAR(80)	No		Acción
entidad	VARCHAR(80)	No		Entidad
id_entidad	VARCHAR(80)	Sí		Id lógico
resultado	VARCHAR(20)	No		Éxito/Error
detalle	TEXT	Sí		Detalle
ip_origen	VARCHAR(64)	Sí		IP
user_agent	VARCHAR(300)	Sí		Agente
fecha_evento	TIMESTAMP	No		Fecha/hora

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: sesiones

Propósito: Controla sesiones activas e históricas.

Campo	Tipo	Nulo	Clave	Descripción
id_sesion	BIGSERIAL	No	PK	Identificador
id_usuario	BIGINT	No	FK	Usuario
token_hash	VARCHAR(255)	No		Token hash
ip_origen	VARCHAR(64)	Sí		IP
user_agent	VARCHAR(300)	Sí		Agente
inicio_at	TIMESTAMP	No		Inicio
ultimo_acceso_at	TIMESTAMP	No		Último acceso
cerrada_at	TIMESTAMP	Sí		Cierre

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: respaldos

Propósito: Registro de copias de seguridad ejecutadas.

Campo	Tipo	Nulo	Clave	Descripción
id_respaldo	BIGSERIAL	No	PK	Identificador
tipo_respaldo	VARCHAR(40)	No		BD/ archivos/ completo
ruta_respaldo	VARCHAR(500)	No		Ruta
tamano_bytes	BIGINT	Sí		Tamaño
hash_verificacion	VARCHAR(128)	Sí		Hash
resultado	VARCHAR(20)	No		Éxito/Error
fecha_ejecucion	TIMESTAMP	No		Fecha/hora
id_usuario	BIGINT	Sí	FK	Responsable

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: configuracion

Propósito: Parámetros generales del sistema.

Campo	Tipo	Nulo	Clave	Descripción
id_configuracion	BIGSERIAL	No	PK	Identificador
clave	VARCHAR(100)	No	UNQ	Clave
valor	TEXT	Sí		Valor
descripcion	VARCHAR(300)	Sí		Detalle
editable	BOOLEAN	No		Editable desde UI

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: notificaciones

Propósito: Avisos operativos dirigidos a usuarios.

Campo	Tipo	Nulo	Clave	Descripción
id_notificacion	BIGSERIAL	No	PK	Identificador
id_usuario	BIGINT	No	FK	Destinatario
titulo	VARCHAR(180)	No		Título
mensaje	TEXT	No		Mensaje
leida	BOOLEAN	No		Indicador
fecha_envio	TIMESTAMP	No		Fecha/hora

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

Tabla: recuperacion_credenciales

Propósito: Tokens temporales para recuperación de acceso.

Campo	Tipo	Nulo	Clave	Descripción
id_recuperacion	BIGSERIAL	No	PK	Identificador
id_usuario	BIGINT	No	FK	Usuario
token_hash	VARCHAR(255)	No		Token hash
expira_at	TIMESTAMP	No		Expiración
usado_at	TIMESTAMP	Sí		Uso
ip_solicitud	VARCHAR(64)	Sí		IP de solicitud

Observaciones técnicas: - Debe definirse índice adicional según consultas frecuentes. - Deben usarse claves foráneas con acciones ON UPDATE/ON DELETE acordes a la política de conservación. - Los campos de trazabilidad created_at, updated_at, created_by y updated_by se recomiendan cuando aplique.

16.4 Relaciones entre tablas

- usuarios 1:N sesiones: un usuario puede mantener varias sesiones históricas.
- usuarios N:M roles mediante usuario_rol: asignación flexible de perfiles.
- roles N:M permisos mediante rol_permiso: matriz de autorización.
- dependencias 1:N usuarios: cada usuario se asocia a una dependencia principal.

- dependencias 1:N documentos: propiedad organizacional del documento.
- tipos_documentales 1:N documentos: clasificación tipológica.
- series_documentales 1:N subseries_documentales: organización archivística.
- subseries_documentales 1:N documentos: ubicación archivística fina.
- clasificaciones 1:N documentos: nivel de acceso y sensibilidad.
- estados_documento 1:N documentos: estado actual del documento.
- documentos 1:N documentos_versiones: historial de versiones.
- documentos 1:N archivos: uno o varios archivos asociados.
- documentos 1:N historial_documento: trazabilidad cronológica.
- usuarios 1:N auditoria: autor material de una acción auditada.
- usuarios 1:N recuperacion_credenciales: solicitudes de recuperación.
- usuarios 1:N notificaciones: mensajes del sistema dirigidos a usuarios.
- respaldos puede relacionarse opcionalmente con usuarios si se registra responsable de ejecución y validación.

16.5 Diccionario de datos resumido

Tabla	Función principal	Claves destacadas
usuarios	identidad de acceso y operación	id_usuario, username, email, password_hash
roles	perfiles de autorización	id_rol, codigo, nombre
permisos	acciones permitidas	id_permiso, modulo, accion
usuario_rol	asignación de roles	id_usuario, id_rol
rol_permiso	matriz de permisos	id_rol, id_permiso
dependencias	áreas institucionales	id_dependencia, codigo, nombre
cargos	catálogo de cargos	id_cargo, nombre
tipos_documentales	catálogo de tipos	id_tipo_documental, codigo, nombre
series_documentales	catálogo archivístico	id_serie, codigo, nombre
subseries_documentales	catálogo archivístico fino	id_subserie, id_serie
clasificaciones	sensibilidad y acceso	id_clasificacion, nombre
estados_documento	ciclo de vida	id_estado, nombre, orden
documentos	metadatos centrales	id_documento, codigo_unico, asunto
documentos_versiones	versiones de metadatos/documento	id_version, id_documento, numero_version
archivos	archivos físicos asociados	id_archivo, id_documento, ruta_almacenamiento, hash_sha256

Tabla	Función principal	Claves destacadas
historial_documento	movimientos del ciclo documental	id_historial, id_documento, id_estado_desde, id_estado_hasta
auditoria	bitácora transversal	id_auditoria, modulo, accion, resultado
sesiones	control de sesiones	id_sesion, id_usuario, token_hash, ultimo_acceso_at
respaldos	control de copias de seguridad	id_respaldo, tipo_respaldo, ruta_respaldo
configuracion	parámetros del sistema	id_configuracion, clave, valor
notificaciones	avisos del sistema	id_notificacion, id_usuario, titulo
recuperacion_credenciales	recuperación de acceso	id_recuperacion, id_usuario, token_hash

16.6 Script SQL propuesto

A continuación se presenta un **script SQL de referencia adaptado a MySQL/MariaDB sobre XAMPP**, adecuado para el prototipo y la implantación piloto de tesis.
Se recomienda utilizar codificación UTF8MB4, motor InnoDB y claves foráneas activas.

```
CREATE DATABASE IF NOT EXISTS gadpr_lm_gestion_documental
CHARACTER SET utf8mb4
COLLATE utf8mb4_unicode_ci;

USE gadpr_lm_gestion_documental;

CREATE TABLE roles (
  id_rol          BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  nombre          VARCHAR(80) NOT NULL UNIQUE,
  descripcion     VARCHAR(255) NULL,
  estado          ENUM('ACTIVO','INACTIVO') NOT NULL DEFAULT 'ACTIVO',
  created_at      DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  updated_at      DATETIME NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE
CURRENT_TIMESTAMP
) ENGINE=InnoDB;

CREATE TABLE dependencias (
  id_dependencia  BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  codigo          VARCHAR(20) NOT NULL UNIQUE,
  nombre          VARCHAR(150) NOT NULL,
  descripcion     VARCHAR(255) NULL,
```

```
  estado              ENUM('ACTIVO','INACTIVO') NOT NULL DEFAULT 'ACTIVO',
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  updated_at          DATETIME NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE
CURRENT_TIMESTAMP
) ENGINE=InnoDB;

CREATE TABLE usuarios (
  id_usuario          BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  id_dependencia      BIGINT UNSIGNED NULL,
  nombres             VARCHAR(120) NOT NULL,
  apellidos           VARCHAR(120) NOT NULL,
  username            VARCHAR(60) NOT NULL UNIQUE,
  correo              VARCHAR(150) NOT NULL UNIQUE,
  password_hash       VARCHAR(255) NOT NULL,
  cargo               VARCHAR(120) NULL,
  telefono            VARCHAR(30) NULL,
  estado              ENUM('ACTIVO','INACTIVO','BLOQUEADO') NOT NULL DEFAULT
'ACTIVO',
  ultimo_acceso       DATETIME NULL,
  intentos_fallidos   INT NOT NULL DEFAULT 0,
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  updated_at          DATETIME NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE
CURRENT_TIMESTAMP,
  CONSTRAINT fk_usuario_dependencia
    FOREIGN KEY (id_dependencia) REFERENCES dependencias(id_dependencia)
    ON UPDATE CASCADE ON DELETE SET NULL
) ENGINE=InnoDB;

CREATE TABLE usuario_rol (
  id_usuario_rol      BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  id_usuario          BIGINT UNSIGNED NOT NULL,
  id_rol              BIGINT UNSIGNED NOT NULL,
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  CONSTRAINT uq_usuario_rol UNIQUE (id_usuario, id_rol),
  CONSTRAINT fk_usuario_rol_usuario
    FOREIGN KEY (id_usuario) REFERENCES usuarios(id_usuario)
    ON UPDATE CASCADE ON DELETE CASCADE,
  CONSTRAINT fk_usuario_rol_rol
    FOREIGN KEY (id_rol) REFERENCES roles(id_rol)
    ON UPDATE CASCADE ON DELETE CASCADE
) ENGINE=InnoDB;

CREATE TABLE permisos (
```

```
  id_permiso          BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  codigo              VARCHAR(80) NOT NULL UNIQUE,
  nombre              VARCHAR(120) NOT NULL,
  modulo              VARCHAR(80) NOT NULL,
  descripcion         VARCHAR(255) NULL,
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP
) ENGINE=InnoDB;

CREATE TABLE rol_permiso (
  id_rol_permiso      BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  id_rol              BIGINT UNSIGNED NOT NULL,
  id_permiso          BIGINT UNSIGNED NOT NULL,
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  CONSTRAINT uq_rol_permiso UNIQUE (id_rol, id_permiso),
  CONSTRAINT fk_rol_permiso_rol
    FOREIGN KEY (id_rol) REFERENCES roles(id_rol)
    ON UPDATE CASCADE ON DELETE CASCADE,
  CONSTRAINT fk_rol_permiso_permiso
    FOREIGN KEY (id_permiso) REFERENCES permisos(id_permiso)
    ON UPDATE CASCADE ON DELETE CASCADE
) ENGINE=InnoDB;

CREATE TABLE tipos_documentales (
  id_tipo_documental  BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  codigo              VARCHAR(30) NOT NULL UNIQUE,
  nombre              VARCHAR(120) NOT NULL,
  descripcion         VARCHAR(255) NULL,
  requiere_versionado TINYINT(1) NOT NULL DEFAULT 1,
  estado              ENUM('ACTIVO','INACTIVO') NOT NULL DEFAULT 'ACTIVO',
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP
) ENGINE=InnoDB;

CREATE TABLE series_documentales (
  id_serie            BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  codigo              VARCHAR(30) NOT NULL UNIQUE,
  nombre              VARCHAR(150) NOT NULL,
  descripcion         VARCHAR(255) NULL,
  estado              ENUM('ACTIVO','INACTIVO') NOT NULL DEFAULT 'ACTIVO',
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP
) ENGINE=InnoDB;

CREATE TABLE subseries_documentales (
  id_subserie         BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
```

```
  id_serie            BIGINT UNSIGNED NOT NULL,
  codigo              VARCHAR(30) NOT NULL,
  nombre              VARCHAR(150) NOT NULL,
  descripcion         VARCHAR(255) NULL,
  estado              ENUM('ACTIVO','INACTIVO') NOT NULL DEFAULT 'ACTIVO',
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  CONSTRAINT uq_subserie UNIQUE (id_serie, codigo),
  CONSTRAINT fk_subserie_serie
    FOREIGN KEY (id_serie) REFERENCES series_documentales(id_serie)
    ON UPDATE CASCADE ON DELETE RESTRICT
) ENGINE=InnoDB;

CREATE TABLE estados_documento (
  id_estado_documento    BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  codigo              VARCHAR(30) NOT NULL UNIQUE,
  nombre              VARCHAR(100) NOT NULL,
  descripcion         VARCHAR(255) NULL,
  orden_flujo         INT NOT NULL DEFAULT 0,
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP
) ENGINE=InnoDB;

CREATE TABLE documentos (
  id_documento          BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  id_dependencia        BIGINT UNSIGNED NOT NULL,
  id_tipo_documental    BIGINT UNSIGNED NOT NULL,
  id_serie              BIGINT UNSIGNED NOT NULL,
  id_subserie           BIGINT UNSIGNED NULL,
  id_estado_documento   BIGINT UNSIGNED NOT NULL,
  id_usuario_registra   BIGINT UNSIGNED NOT NULL,
  codigo_documento      VARCHAR(100) NOT NULL UNIQUE,
  titulo                VARCHAR(255) NOT NULL,
  descripcion           TEXT NULL,
  fecha_documento       DATE NOT NULL,
  fecha_registro        DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  nivel_confidencialidad  ENUM('PUBLICO','INTERNO','RESERVADO','CONFIDENCIAL')
NOT NULL DEFAULT 'INTERNO',
  palabras_clave        VARCHAR(255) NULL,
  observaciones         TEXT NULL,
  estado                ENUM('ACTIVO','ARCHIVADO','ELIMINADO_LOGICO') NOT NULL
DEFAULT 'ACTIVO',
  created_at            DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  updated_at            DATETIME NULL DEFAULT CURRENT_TIMESTAMP ON UPDATE
CURRENT_TIMESTAMP,
```

```
  CONSTRAINT fk_documento_dependencia
    FOREIGN KEY (id_dependencia) REFERENCES dependencias(id_dependencia)
    ON UPDATE CASCADE ON DELETE RESTRICT,
  CONSTRAINT fk_documento_tipo
    FOREIGN KEY (id_tipo_documental) REFERENCES
tipos_documentales(id_tipo_documental)
    ON UPDATE CASCADE ON DELETE RESTRICT,
  CONSTRAINT fk_documento_serie
    FOREIGN KEY (id_serie) REFERENCES series_documentales(id_serie)
    ON UPDATE CASCADE ON DELETE RESTRICT,
  CONSTRAINT fk_documento_subserie
    FOREIGN KEY (id_subserie) REFERENCES subseries_documentales(id_subserie)
    ON UPDATE CASCADE ON DELETE SET NULL,
  CONSTRAINT fk_documento_estado
    FOREIGN KEY (id_estado_documento) REFERENCES
estados_documento(id_estado_documento)
    ON UPDATE CASCADE ON DELETE RESTRICT,
  CONSTRAINT fk_documento_usuario
    FOREIGN KEY (id_usuario_registra) REFERENCES usuarios(id_usuario)
    ON UPDATE CASCADE ON DELETE RESTRICT
) ENGINE=InnoDB;

CREATE TABLE documentos_versiones (
  id_version          BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  id_documento        BIGINT UNSIGNED NOT NULL,
  numero_version      INT NOT NULL,
  id_usuario_crea     BIGINT UNSIGNED NOT NULL,
  motivo_cambio       VARCHAR(255) NULL,
  observaciones       TEXT NULL,
  created_at          DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  CONSTRAINT uq_documento_version UNIQUE (id_documento, numero_version),
  CONSTRAINT fk_version_documento
    FOREIGN KEY (id_documento) REFERENCES documentos(id_documento)
    ON UPDATE CASCADE ON DELETE CASCADE,
  CONSTRAINT fk_version_usuario
    FOREIGN KEY (id_usuario_crea) REFERENCES usuarios(id_usuario)
    ON UPDATE CASCADE ON DELETE RESTRICT
) ENGINE=InnoDB;

CREATE TABLE archivos (
  id_archivo          BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  id_documento        BIGINT UNSIGNED NOT NULL,
  id_version          BIGINT UNSIGNED NULL,
```

```
  nombre_original        VARCHAR(255) NOT NULL,
  nombre_almacenado      VARCHAR(255) NOT NULL,
  extension              VARCHAR(15) NOT NULL,
  mime_type              VARCHAR(120) NOT NULL,
  tamano_bytes           BIGINT UNSIGNED NOT NULL,
  hash_sha256            VARCHAR(128) NOT NULL,
  ruta_almacenamiento    VARCHAR(500) NOT NULL,
  es_principal           TINYINT(1) NOT NULL DEFAULT 1,
  estado                 ENUM('ACTIVO','INACTIVO') NOT NULL DEFAULT 'ACTIVO',
  created_at             DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  CONSTRAINT fk_archivo_documento
    FOREIGN KEY (id_documento) REFERENCES documentos(id_documento)
    ON UPDATE CASCADE ON DELETE CASCADE,
  CONSTRAINT fk_archivo_version
    FOREIGN KEY (id_version) REFERENCES documentos_versiones(id_version)
    ON UPDATE CASCADE ON DELETE SET NULL
) ENGINE=InnoDB;

CREATE TABLE auditoria (
  id_auditoria           BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  id_usuario             BIGINT UNSIGNED NULL,
  modulo                 VARCHAR(80) NOT NULL,
  accion                 VARCHAR(80) NOT NULL,
  entidad                VARCHAR(80) NOT NULL,
  id_registro_afectado   VARCHAR(80) NULL,
  direccion_ip           VARCHAR(45) NULL,
  user_agent             VARCHAR(255) NULL,
  detalle                TEXT NULL,
  fecha_evento           DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  CONSTRAINT fk_auditoria_usuario
    FOREIGN KEY (id_usuario) REFERENCES usuarios(id_usuario)
    ON UPDATE CASCADE ON DELETE SET NULL
) ENGINE=InnoDB;

CREATE TABLE sesiones (
  id_sesion              BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  id_usuario             BIGINT UNSIGNED NOT NULL,
  token_sesion           VARCHAR(255) NOT NULL,
  direccion_ip           VARCHAR(45) NULL,
  user_agent             VARCHAR(255) NULL,
  fecha_inicio           DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  fecha_ultimo_acceso    DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  fecha_expiracion       DATETIME NOT NULL,
```

```
  estado              ENUM('ACTIVA','CERRADA','EXPIRADA') NOT NULL DEFAULT
'ACTIVA',
  CONSTRAINT fk_sesion_usuario
    FOREIGN KEY (id_usuario) REFERENCES usuarios(id_usuario)
    ON UPDATE CASCADE ON DELETE CASCADE
) ENGINE=InnoDB;

CREATE TABLE recuperacion_credenciales (
  id_recuperacion       BIGINT UNSIGNED AUTO_INCREMENT PRIMARY KEY,
  id_usuario            BIGINT UNSIGNED NOT NULL,
  token_recuperacion    VARCHAR(255) NOT NULL,
  fecha_solicitud       DATETIME NOT NULL DEFAULT CURRENT_TIMESTAMP,
  fecha_expiracion      DATETIME NOT NULL,
  usado                 TINYINT(1) NOT NULL DEFAULT 0,
  CONSTRAINT fk_recuperacion_usuario
    FOREIGN KEY (id_usuario) REFERENCES usuarios(id_usuario)
    ON UPDATE CASCADE ON DELETE CASCADE
) ENGINE=InnoDB;

CREATE INDEX idx_documentos_fecha_documento ON documentos(fecha_documento);
CREATE INDEX idx_documentos_dependencia ON documentos(id_dependencia);
CREATE INDEX idx_documentos_tipo ON documentos(id_tipo_documental);
CREATE INDEX idx_documentos_estado ON documentos(id_estado_documento);
CREATE INDEX idx_auditoria_fecha_evento ON auditoria(fecha_evento);
CREATE INDEX idx_archivos_hash ON archivos(hash_sha256);
```

Observación técnica: en XAMPP, la base puede administrarse con phpMyAdmin para tareas de revisión y soporte, pero el despliegue formal debe conservar scripts versionados y controlados en el repositorio del proyecto.

16.7 Integridad y normalización

- Las tablas deben mantenerse al menos en **Tercera Forma Normal (3FN)** para reducir redundancia.
- Los catálogos deben separarse de las tablas transaccionales.
- Las claves foráneas deben impedir registros huérfanos.
- Los índices deben diseñarse sobre campos de búsqueda frecuente, como codigo_unico, fecha_documento, id_dependencia, id_tipo_documental, id_estado_actual.
- Los metadatos de archivo deben separarse del contenido físico del archivo.
- Los cambios históricos no deben sobrescribir evidencia previa; por ello se requieren tablas de historial y versionado.

16.8 Tablas mínimas sugeridas

Se consideran obligatorias las tablas usuarios, roles, permisos, usuario_rol, rol_permiso, dependencias, cargos, tipos_documentales, series_documentales, subseries_documentales, documentos, documentos_versiones, archivos, clasificaciones, estados_documento, historial_documento, auditoria, sesiones, respaldos, configuracion, notificaciones y recuperacion_credenciales.
Se podrán incorporar tablas adicionales como documentos_relacionados, retenciones_documentales, colas_digitalizacion, firmas, etiquetas_documentales o incidentes_seguridad, según la evolución del proyecto.

17. Diseño de formularios y campos

17.1 Formulario de inicio de sesión

- **Objetivo:** autenticar al usuario.
- **Campos:** usuario o correo, contraseña, segundo factor si aplica.
- **Validaciones:** obligatoriedad, longitud mínima, formato de correo si se ingresa email.
- **Mensajes:** “Credenciales inválidas o cuenta no disponible”.
- **Restricciones:** no revelar si el usuario existe.

17.2 Formulario de registro documental

- **Campos:** código interno o autogenerado, número documental, asunto, fecha, dependencia, tipo documental, serie, subserie, clasificación, observaciones.
- **Validaciones:** asunto obligatorio, fecha válida, catálogos activos, correspondencia serie-subserie.
- **Controles:** listas desplegables, selector de fecha, áreas de texto, adjuntos posteriores o integrados.
- **Procesamiento:** guardar borrador o confirmar registro.

17.3 Formulario de carga de archivos

- **Campos:** selector de archivo, descripción del archivo, indicador de archivo principal, observación.
- **Validaciones:** tamaño máximo, extensión permitida, MIME real, antivirus si existe integración.
- **Mensajes:** confirmación de carga, error por archivo bloqueado, error por formato no permitido.

17.4 Formulario de búsqueda avanzada

- **Campos:** código, asunto, dependencia, tipo documental, serie, subserie, clasificación, estado, fecha desde, fecha hasta, texto libre.
- **Validaciones:** rango de fechas coherente, longitud de texto, filtros compatibles.
- **Resultado:** tabla paginada con acciones disponibles por fila.

17.5 Formulario de usuarios

- **Campos:** username, nombres, apellidos, correo, dependencia, cargo, roles, estado.
- **Validaciones:** unicidad de usuario/correo, obligatoriedad de datos básicos, al menos un rol activo.
- **Mensajes:** confirmación de creación, activación, bloqueo o restablecimiento.

17.6 Formulario de recuperación de contraseña

- **Campos:** correo o usuario.
- **Validaciones:** dato obligatorio.
- **Comportamiento:** siempre muestra mensaje neutro; si el usuario existe y está habilitado, genera token temporal.

17.7 Formulario de cambios de estado

- **Campos:** estado destino, observación, justificativo cuando aplique.
- **Validaciones:** transición permitida, permiso del rol, metadatos completos.
- **Resultado:** actualización del estado + historial + auditoría.

18. Reportes del sistema

18.1 Inventario documental

- **Objetivo:** conocer el universo documental registrado.
- **Filtros:** dependencia, fecha, tipo, clasificación, estado.
- **Columnas:** código, número, asunto, fecha, dependencia, tipo, estado, clasificación.
- **Fuente:** tabla documentos y catálogos asociados.
- **Salida:** pantalla, PDF, Excel.
- **Usuario autorizado:** supervisor, gestor documental, administrador.

18.2 Documentos por área

- **Objetivo:** medir carga documental por dependencia.
- **Filtros:** rango de fechas, dependencia, estado.
- **Columnas:** dependencia, total documentos, borradores, archivados, observados.
- **Salida:** tabla y gráfico.

18.3 Documentos por tipo

- **Objetivo:** analizar distribución tipológica.
- **Filtros:** tipo, fechas, dependencia.
- **Columnas:** tipo documental, total, porcentaje.

18.4 Documentos por rango de fechas

- **Objetivo:** revisar producción documental en período.
- **Filtros:** fecha desde/hasta, dependencia, tipo.

18.5 Documentos por estado

- **Objetivo:** identificar atrasos y concentración por fase documental.
- **Columnas:** estado, total, porcentaje, tiempo promedio en estado si se implementa.

18.6 Historial de movimientos

- **Objetivo:** revisar trazabilidad por documento.
- **Filtros:** código documental, fechas, usuario, estado.
- **Columnas:** fecha, usuario, acción, estado desde, estado hasta, observación.

18.7 Usuarios activos

- **Objetivo:** controlar accesos y actividad.
- **Filtros:** dependencia, rol, estado.
- **Columnas:** usuario, rol, último acceso, sesiones activas.

18.8 Auditoría de accesos

- **Objetivo:** verificar eventos de seguridad y uso.
- **Filtros:** usuario, módulo, acción, resultado, fecha.
- **Columnas:** fecha, usuario, IP, módulo, acción, resultado.

18.9 Reporte de carga documental

- **Objetivo:** medir productividad del registro y digitalización.
- **Filtros:** gestor documental, dependencia, fechas.
- **Columnas:** usuario, cantidad registrada, cantidad con archivo, pendientes.

18.10 Reporte de respaldos

- **Objetivo:** evidenciar continuidad operativa.
- **Filtros:** tipo, fechas, resultado.
- **Columnas:** fecha, tipo de respaldo, ubicación, tamaño, ejecutado por, validado.

19. Seguridad del sistema

Ajuste de entorno: dado que el proyecto de tesis se ejecutará sobre **XAMPP** y puede exponerse temporalmente mediante **ngrok**, los controles de seguridad deben contemplar tanto la protección del entorno local como la exposición puntual del sistema fuera de la intranet.
En consecuencia: - XAMPP debe configurarse con servicios mínimos habilitados. - phpMyAdmin no debe permanecer expuesto públicamente por ngrok. - el túnel ngrok solo debe abrirse durante pruebas controladas; - las credenciales deben almacenarse en archivo de entorno y no en código fuente; - la aplicación debe validar sesiones, roles y archivos cargados como si operara en un entorno productivo restringido.

19.1 Autenticación segura

- Contraseñas almacenadas con hash robusto (por ejemplo Argon2id).
- Políticas de complejidad y bloqueo.

- Posibilidad de segundo factor para administradores.
- Relación normativa: ISO/IEC 27001 control de acceso; OWASP ASVS secciones de autenticación.

19.2 Control de acceso basado en roles

- RBAC con permisos por módulo y acción.
- Segregación de funciones.
- Filtrado por dependencia y clasificación.
- Relación normativa: ISO/IEC 27001 (privilegios y segregación) e ISO 15489 (acceso controlado a registros).

19.3 Gestión de sesiones

- Cookies HttpOnly, Secure cuando aplique, SameSite.
- Rotación de identificador de sesión en eventos críticos.
- Expiración por inactividad.
- Revocación manual por administrador.
- Relación normativa: OWASP ASVS secciones de sesión.

19.4 Protección contra ataques comunes

- Validación y sanitización de entradas.
- Protección CSRF en formularios autenticados.
- Control de rate limiting en login y recuperación.
- Prevención de IDOR usando verificaciones por servidor.
- Prevención de inyección mediante ORM/consultas parametrizadas.
- Encabezados de seguridad y CSP cuando sea viable.

19.5 Seguridad de archivos cargados

- Lista blanca de extensiones.
- Verificación MIME real.
- Tamaño máximo configurable.
- Almacenamiento fuera del directorio público.
- Renombrado interno.
- Hash de integridad.
- Opcional: análisis antivirus en cuarentena.

19.6 Auditoría y registros

- Eventos de autenticación, cambios de permisos, cargas, descargas, cambios de estado, errores críticos y respaldos.
- Timestamps sincronizados.
- Protección de logs contra alteración.
- Relación normativa: ISO/IEC 27001 monitoreo y logging; ISO 15489 trazabilidad.

19.7 Protección de datos sensibles

- Minimización de datos personales.
- Cifrado de secretos de aplicación.
- Cifrado de respaldos cuando sea necesario.
- Control de visibilidad según clasificación del documento.

19.8 Manejo de errores

- Mensajes neutros al usuario.
- Detalle técnico solo en logs.
- Correlación de incidentes con identificadores internos.

19.9 Respaldo y recuperación

- Copias programadas de base de datos.
- Copias del repositorio documental.
- Pruebas periódicas de restauración.
- Retención definida por política institucional.
- Relación normativa: ISO/IEC 27001 continuidad y disponibilidad.

20. Diseño de experiencia de usuario e interfaz

- La interfaz debe priorizar claridad sobre ornamentación.
- El dashboard debe presentar indicadores resumidos y accesos rápidos.
- Los formularios largos deben agruparse en secciones.
- Los mensajes de error deben indicar qué corregir, no solo que existe un error.
- Los botones primarios deben distinguirse claramente de los secundarios.
- Las acciones destructivas deben requerir confirmación explícita.
- Debe existir consistencia en iconografía, colores y posiciones de acciones.
- Debe contemplarse accesibilidad básica: contraste adecuado, textos legibles, foco visible, etiquetas de formulario y navegación por teclado en acciones esenciales.
- La visualización documental debe usar panel con metadatos a un lado y vista previa al centro cuando el formato lo permita.

21. Diseño de pruebas

En un proyecto de tesis, las pruebas no solo verifican el funcionamiento del sistema, sino que generan evidencia empírica para sustentar la validación técnica de la propuesta. Por ello, su diseño debe facilitar la elaboración posterior de resultados, análisis y conclusiones del trabajo de titulación.

21.1 Estructura del plan de pruebas

Se recomienda combinar pruebas funcionales, de seguridad, de validación y de continuidad.

Código	Caso de prueba	Objetivo
CP-LOGIN-01	Inicio de sesión válido	verificar autenticación correcta
CP-LOGIN-02	Inicio de sesión inválido	verificar mensaje neutro y no filtración
CP-USR-01	Crear usuario	verificar persistencia y reglas de unicidad
CP-DOC-01	Registrar documento completo	verificar creación correcta
CP-DOC-02	Registrar documento sin metadatos obligatorios	verificar rechazo
CP-ARC-01	Cargar archivo permitido	verificar validación y hash
CP-ARC-02	Cargar archivo prohibido	verificar bloqueo
CP-BUS-01	Búsqueda avanzada	verificar filtrado correcto y permisos
CP-EST-01	Cambio de estado permitido	verificar transición
CP-EST-02	Cambio de estado no permitido	verificar rechazo
CP-AUD-01	Generación de auditoría	verificar trazabilidad
CP-RPT-01	Exportar reporte	verificar formato y permisos
CP-SEC-01	Intentos fallidos de login	verificar bloqueo
CP-SES-01	Expiración por inactividad	verificar cierre automático
CP-BKP-01	Ejecución de respaldo	verificar registro
CP-BKP-02	Restauración de respaldo	verificar recuperación controlada

21.2 Ejemplo de caso de prueba detallado

Código: CP-DOC-01
Objetivo: verificar el registro exitoso de un documento.
Precondiciones: usuario gestor documental autenticado; catálogos activos cargados.
Pasos: 1. Ingresar al módulo nuevo documento. 2. Completar campos obligatorios válidos. 3. Presionar Guardar. 4. Revisar confirmación y listado.
Resultado esperado: documento creado con código único, historial inicial y auditoría registrada.

Código: CP-ARC-02
Objetivo: validar rechazo de archivo peligroso.
Precondiciones: documento en borrador; usuario autorizado.
Pasos: 1. Ingresar al módulo carga. 2. Seleccionar archivo con extensión prohibida. 3. Presionar Cargar.
Resultado esperado: el sistema rechaza el archivo, informa restricción y registra intento relevante.

22. Plan de implementación

Como proyecto de tesis, la implementación debe ejecutarse de forma gradual, controlada y documentada, considerando que el entorno base indicado para el sistema es **XAMPP + MySQL/MariaDB + Apache**, y que **ngrok** será utilizado únicamente para exposición temporal en pruebas externas o demostraciones académicas.

22.1 Etapa 1: preparación del entorno

1. Seleccionar el equipo o servidor institucional donde funcionará el prototipo o piloto.
2. Verificar capacidad mínima: procesador adecuado, memoria suficiente, espacio para base de datos y repositorio documental, y estabilidad eléctrica.
3. Instalar sistema operativo compatible, preferiblemente Windows institucional controlado.
4. Instalar **XAMPP** con componentes mínimos necesarios:
   - Apache
   - MySQL/MariaDB
   - PHP
   - phpMyAdmin
5. Configurar puertos y evitar conflictos con otros servicios del sistema operativo.
6. Crear estructura de carpetas del proyecto:
   - carpeta de aplicación
   - carpeta de almacenamiento documental
   - carpeta de respaldos
   - carpeta de logs
7. Restringir permisos del sistema de archivos para evitar acceso no autorizado a documentos y respaldos.
8. Definir URL local del sistema, por ejemplo: http://localhost/gadpr-lm-docs o URL interna equivalente.

22.2 Etapa 2: despliegue de base de datos en XAMPP

1. Iniciar el servicio MySQL/MariaDB desde el panel de control de XAMPP.
2. Crear la base de datos institucional usando script SQL versionado.
3. Crear usuario técnico de base de datos con privilegios controlados.
4. Aplicar tablas, índices, claves foráneas y catálogos iniciales.
5. Registrar credenciales de conexión en archivo de entorno seguro del proyecto.
6. Probar conexión desde la aplicación.
7. Configurar rutina de exportación de respaldos .sql.
8. Validar restauración en ambiente de prueba antes de pasar a operación.

22.3 Etapa 3: despliegue de backend y frontend en Apache/XAMPP

1. Ubicar el proyecto Laravel/PHP en el directorio correspondiente de XAMPP.
2. Configurar archivo .env con:
   - nombre de base de datos

    - usuario y contraseña
    - ruta de almacenamiento documental
    - correo saliente si aplica
    - claves de aplicación
3. Generar clave de aplicación.
4. Ejecutar migraciones o scripts iniciales, según la estrategia adoptada.
5. Configurar permisos de escritura únicamente en directorios requeridos.
6. Validar carga de recursos estáticos, formularios, sesiones y autenticación.
7. Probar subida y consulta de archivos desde el navegador institucional.

22.4 Etapa 4: configuración de almacenamiento documental

1. Crear repositorio documental fuera del directorio público de Apache.
2. Definir estructura por dependencia, serie, subserie, año o clasificación.
3. Configurar lógica de nombres internos únicos para evitar colisiones.
4. Registrar hash del archivo al momento de la carga.
5. Validar apertura, descarga y control de acceso desde la aplicación.
6. Probar recuperación manual de un archivo a partir de su ruta y metadatos.

22.5 Etapa 5: configuración de ngrok para pruebas controladas

1. Instalar ngrok en el equipo donde se ejecuta XAMPP.
2. Autenticar ngrok con la cuenta autorizada del proyecto.
3. Levantar túnel únicamente cuando se requiera evaluación externa, demostración o validación remota.
4. Asociar el túnel al puerto usado por Apache, normalmente 80 o el configurado localmente.
5. Verificar que la URL generada sea accesible desde el exterior.
6. Confirmar que el sistema funcione correctamente bajo HTTPS de ngrok.
7. Registrar fecha, hora, responsable y motivo de activación del túnel.
8. Cerrar el túnel al finalizar la prueba.

Regla de seguridad: ngrok no debe considerarse infraestructura permanente de producción; su uso se limita a fines de tesis, revisión remota y pruebas temporales.

22.6 Etapa 6: pruebas técnicas y funcionales

1. Probar login, recuperación de contraseña, sesiones y cierre de sesión.
2. Probar creación de usuarios, roles y permisos.
3. Probar registro documental, carga de archivos, indexación y consulta.
4. Probar restricciones por rol y dependencia.
5. Probar bitácora y auditoría.
6. Probar reportes y exportaciones.
7. Probar respaldo y restauración.
8. Probar acceso local y acceso temporal vía ngrok.
9. Documentar incidencias, capturas y resultados para sustento de tesis.

22.7 Etapa 7: capacitación y validación con usuarios

1. Capacitar a administrador, gestores documentales y usuarios institucionales.
2. Realizar sesión guiada de uso del sistema.
3. Levantar observaciones de mejora.
4. Ejecutar correcciones priorizadas.
5. Aplicar validación final del prototipo o piloto.

22.8 Etapa 8: puesta en marcha controlada

1. Cargar catálogos y usuarios iniciales.
2. Habilitar módulos aprobados.
3. Activar política de respaldos.
4. Verificar auditoría, logs y sesión.
5. Supervisar operación durante periodo inicial controlado.
6. Documentar resultados obtenidos para el informe final de tesis.

22.9 Control de cambios y versionamiento

- Mantener repositorio Git del proyecto.
- Versionar scripts SQL, configuraciones, plantillas y documentación.
- Registrar cambios funcionales, técnicos y de seguridad.
- Separar ambiente local de desarrollo, ambiente de prueba y ambiente demostrativo.
- Documentar cualquier cambio de puertos, rutas, configuración de XAMPP o uso de ngrok.

23. Plan de mantenimiento

23.1 Preventivo

- revisión de logs;
- verificación de respaldos;
- actualización de dependencias;
- revisión de capacidad de almacenamiento;
- revisión de cuentas inactivas.

23.2 Correctivo

- atención de errores;
- corrección de fallos funcionales;
- recuperación ante incidentes;
- restauración puntual si procede.

23.3 Evolutivo

- nuevos reportes;
- ajustes de flujos;
- mejoras de seguridad;

- integraciones futuras como firma electrónica o interoperabilidad, fuera del alcance base.

23.4 Monitoreo

- estado del servidor;
- salud de base de datos;
- espacio de almacenamiento;
- resultados de tareas programadas;
- intentos fallidos y eventos críticos.

24. Riesgos del proyecto y mitigación

Riesgo específico de entorno: debido al uso de XAMPP y ngrok en fase de tesis, debe mitigarse el riesgo de exposición accidental del sistema o de herramientas administrativas. La mitigación incluye deshabilitar accesos innecesarios, restringir phpMyAdmin, abrir túneles solo temporalmente y cerrar la exposición al finalizar cada prueba.

Riesgo	Impacto	Probabilidad	Mitigación
Requerimientos incompletos	Alto	Media	validación temprana con usuarios clave y prototipos
Falta de datos limpios para migración inicial	Medio	Alta	plantillas de carga y depuración previa
Resistencia al cambio	Medio	Media	capacitación y acompañamiento
Configuración insegura del servidor	Alto	Media	hardening, revisión y checklists
Pérdida de archivos por mala política de respaldo	Alto	Baja/Media	estrategia 3-2-1 adaptada y pruebas de restauración
Asignación incorrecta de permisos	Alto	Media	matriz de roles, pruebas de autorización y segregación
Sobrecarga de almacenamiento	Medio	Media	monitoreo de capacidad y políticas de retención
Errores de clasificación documental	Medio	Media	catálogos claros, validaciones y capacitación

Riesgo	Impacto	Probabilidad	Mitigación
Exposición de información sensible en reportes	Alto	Baja/Media	filtro por permisos y revisión de exportaciones
Dependencia de una sola persona técnica	Medio	Media	documentación y transferencia de conocimiento

25. Conclusiones y recomendaciones técnicas

Las conclusiones aquí planteadas deben leerse también como conclusiones técnicas preliminares del proyecto de tesis, útiles para justificar la viabilidad, pertinencia e impacto esperado de la solución propuesta.

1. El proyecto es técnicamente viable y responde a una necesidad institucional real de orden, control y trazabilidad documental.
2. La combinación de gestión documental y seguridad de la información exige que el sistema se diseñe desde el inicio con controles formales y no como agregados posteriores.
3. La adopción práctica de ISO/IEC 27001:2022, ISO 15489 y OWASP ASVS fortalece la calidad técnica, operativa y probatoria del sistema.
4. La arquitectura por capas, el uso de catálogos normalizados, el repositorio documental seguro y la auditoría integral permiten una base sólida para crecimiento futuro.
5. Se recomienda iniciar con un producto mínimo institucionalmente útil que incluya autenticación, usuarios, roles, dependencias, tipos documentales, registro documental, archivos, búsqueda, historial, auditoría y reportes base.
6. Antes del desarrollo definitivo debe validarse con la institución la matriz de roles, la clasificación documental, la política de retención, la estrategia de respaldos y la infraestructura disponible.
7. También se recomienda elaborar como documentos complementarios: matriz CRUD por rol, diagramas UML, prototipos de interfaz, plan de pruebas ampliado, manual de usuario, manual técnico y plan de continuidad operativa.

Anexos sugeridos para una versión ampliada del expediente

- Matriz de requerimientos vs módulos.
- Matriz de roles y permisos.
- Diagramas de casos de uso.
- Diagrama entidad-relación formal.
- Prototipos de pantallas.
- Checklist ASVS adaptado al proyecto.
- Política resumida de clasificación y retención documental.
- Plan detallado de respaldos y restauración.

Enfoque recomendado para integrar este expediente dentro de la tesis

Para mantener coherencia académica, se recomienda utilizar este expediente de la siguiente manera dentro del trabajo de titulación:

- **Capítulo I o diagnóstico del problema:** usar los apartados de antecedentes, problemática y justificación para sustentar la necesidad institucional.
- **Capítulo II o marco teórico/normativo:** usar el marco normativo y técnico aplicable, articulando ISO/IEC 27001:2022, ISO 15489 y OWASP ASVS con la propuesta.
- **Capítulo III o metodología:** relacionar los apartados de metodología de desarrollo, levantamiento de requerimientos, actores y plan de pruebas con la metodología de investigación y desarrollo del sistema.
- **Capítulo IV o propuesta tecnológica / desarrollo:** emplear la arquitectura, módulos, navegación, reglas de negocio, base de datos, formularios, reportes, seguridad e implementación como cuerpo técnico principal.
- **Capítulo V o validación y resultados:** aprovechar el plan de pruebas, indicadores de funcionamiento, auditoría y controles de seguridad para documentar evidencias de validación.
- **Anexos:** incorporar el expediente completo, scripts SQL, prototipos, matriz de roles, casos de prueba y respaldos de configuración.

Recomendación final de tesis

Se recomienda que la versión definitiva del expediente técnico sea alineada con: 1. el título oficial aprobado por la universidad; 2. la línea de investigación institucional; 3. el problema, objetivo general e hipótesis o preguntas de investigación definidas formalmente; 4. la metodología de tesis adoptada por la carrera; 5. los formatos de citación, numeración y anexos exigidos por la universidad.

De esta manera, el expediente técnico no quedará como un documento aislado, sino como una pieza central plenamente integrada al proyecto de tesis.